Department of Computer Science and Engineering

23CSE336 – Secure Networks

Case Study CS07 | CO3: Firewalls – packet filtering, stateful inspection and NGFW

Replacing a Stateless Packet Filter with Segmentation and a Next-Generation Firewall in a Hospital Network

Protecting an EMR, unpatched medical devices and research data at Sanjivani Multi-Speciality Hospital

Submitted by

Name	Roll number	Part owned
Janhavi Harish Kulkarni	CSE23127	Part I – Foundations, threats and risk
Debapriya Kundu	CSE23115	Part II – Architecture, protocols and CIA
Vedhesh Dhinakaran	CSE23257	Part III – Rule base, NGFW policy and verification
Vundela Lasya	CSE23258	Part IV – Lab, monitoring, response and compliance

Submitted to
Dr. Kumaran U

October 27, 2026

Abstract

Sanjivani Multi-Speciality Hospital runs its entire internal network (the EMR, over a thousand clinical PCs, networked infusion pumps and ventilators, radiology and a research lab) as one flat network behind a single stateless packet filter. Three incidents showed what this costs: a personal laptop plugged into a medical-device port could browse the device subnet, a compromised radiology workstation reached the EMR database on TCP 1433, and a forgotten `permit any any` rule gave vendor Wi-Fi access to clinical systems.

In this report we redesign the network. We start by showing why a stateless filter cannot meet the hospital's needs, using its five testable failures, and we choose a next-generation firewall (NGFW) based on what each firewall generation can actually decide on. We then divide the network into ten zones with every inter-zone flow passing through a redundant NGFW pair, pick a secure protocol for every required flow, and write a complete 60-rule policy that is default-deny, correctly ordered, and gives every rule an owner, a reason, a log setting and a review date. While checking the reference design in the case brief against the original incidents, we found nine gaps. The most serious is that the brief's own radiology rule still lets the whole radiology subnet reach the EMR database on port 1433, which is exactly how incident F2 happened.

We test the design in an OPNsense lab in VirtualBox, using Suricata for intrusion prevention and Zenarmor for application identification. Eight experiments reproduce the incidents, compare stateless and stateful behaviour, show how rule order can silently break a policy, and check each boundary with `nmap`, `tcpdump` and the firewall logs. Finally we cover monitoring, SIEM use cases, incident response playbooks, ongoing rule-base management and how the design maps to HIPAA, PCI DSS v4.0, IEC 80001-1, the DPDP Act 2023 and the CERT-In 2022 directions.

Team Contributions

We split the work into four parts so that each of us owned one complete line of work, from analysis through to evidence. Everyone reviewed the full report before submission. Table 1 shows who led what.

Table 1: Division of work

Member	Chapters led	Exhibits and artefacts produced	Share
Janhavi Harish Kulkarni	Part I: Ch. 2, 3, 4	Firewall-generation comparison and selection matrix; state-table trace; asset register; STRIDE model per zone; MITRE ATT&CK mapping; risk register and heat maps	25%
Debapriya Kundu	Part II: Ch. 5, 6, 7	Before/after network diagrams; ten-zone model; VLAN and IP plan; access-layer hardening standard; vendor access design; secure protocol register; CIA analysis per zone	25%
Vedhesh Dhinakaran	Part III: Ch. 8, 9, 10	Object model and naming convention; complete 60-entry rule base; NGFW profiles (App-ID, URL, file, IPS, TLS); critique of reference design; verification matrix; rule-hit counter review	25%
Vundela Lasya	Part IV: Ch. 11–14	OPNsense lab build and eight experiments; monitoring requirements and SIEM use cases; incident response playbooks; continuous-monitoring calendar; compliance mapping	25%
All	Ch. 1, 15	Problem framing, conclusion, editing and references	shared

The parts depend on each other: the IP plan in Part II sets the addresses used in the rule base in Part III, that rule base is what we build and test in the lab in Part IV, and the residual risk scores in Part I assume the controls that the lab confirms.

Contents

Team Contributions **i**

1 Introduction **1**

Part I Foundations, Threats and Risk **2**

2 Firewall Foundations and Generation Selection **2**

3 Identification of Security Threats and Attacks **6**

4 Security Risk Identification and Analysis **8**

Part II Architecture, Protocols and CIA **11**

5 Network Architecture and Segmentation **11**

6 Selection of Appropriate Secure Protocols **15**

7 Protection of Confidentiality, Integrity and Availability **16**

Part III Rule Base, NGFW Policy and Verification **18**

8 Rule-Base Design and NGFW Policy **18**

9 Critique of the Reference Design **23**

10 Justification and Effectiveness **24**

Part IV Laboratory, Monitoring, Response and Compliance **26**

11 Laboratory Implementation and Results **26**

12 Network Monitoring Requirements and Tools **31**

13 Incident Detection and Response **33**

14 Continuous Monitoring, Risk Management and Compliance **35**

15 Conclusion **37**

References **37**

1 Introduction

1.1 Organisation and context

Sanjivani Multi-Speciality Hospital operates a 700-bed main campus, a dialysis wing and an attached biomedical research laboratory. Clinical operations depend on a hospital information system (HIS) built around an electronic medical record (EMR), on networked medical devices at the bedside, on a picture archiving and communication system (PACS) for imaging, and on a large population of nurses' stations, doctors' workstations and administrative PCs. Visitors, vendors and medical engineers also connect over wireless.

The entire internal estate is a single flat routed network. The only security control is a first-generation stateless packet-filtering firewall at the internet edge. No internal traffic ever passes through it. Table 1.1 lists the six functional segments named in the case brief and the only flows each one genuinely needs.

Table 1.1: Functional segments and their required flows (from the case brief)

Segment	Content	Required flows only
HIS / EMR servers	EMR database, application, pharmacy, billing	Clinical apps in; backup out
Medical devices	Infusion pumps, ventilators, monitors, syringe pumps	EMR interface engine, DNS, NTP
Radiology / imaging	CT, MRI, ultrasound, PACS, reading workstations	DICOM to named PACS nodes
Clinical / admin	Nurses' stations, doctors, registration, HR, biomedical engineering	EMR, directory, internet
Guest and vendor Wi-Fi	Visitors; vendor and medical-engineer laptops	Internet only
Research lab	Assay instruments, bioinformatics compute	Own subnet, inspected egress

1.2 Problem statement

The existing rule base consists of four entries: internet to the web servers, DNS to the internal resolvers, HIS hosts to the database, and `permit any any` to the vendor VLAN. The last rule was added so that one engineer could finish a firmware session and was never removed. Three findings forced a redesign:

F1. Rogue laptop on the device network. An engineer connected a personal laptop to a medical-device port and browsed the device subnet freely.

F2. Radiology to EMR. A compromised radiology workstation reached the EMR database on TCP 1433, because both systems sat in the same flat network and the traffic never crossed a firewall.

F3. Vendor Wi-Fi reach. Vendor wireless had broad access into clinical systems through the `permit any any` rule.

The brief from hospital management is short: *install an NGFW, segment the estate, and produce a rule base a regulator can inspect.*

1.3 Objectives

(1) Explain with testable evidence why the stateless filter fails and select the right firewall generation per requirement; (2) identify assets, threats and risks per zone; (3) design a segmented network in which every inter-zone flow is forced through the firewall, plus the access-layer controls a firewall cannot provide; (4) select a secure protocol for every flow; (5) write a complete, default-deny, ordered and auditable rule base with NGFW inspection profiles; (6) verify the design in a working lab and define the monitoring, response and governance that keep it effective.

1.4 Scope and assumptions

- The design covers the main campus, dialysis wing and research laboratory as one site with a single internet edge. A disaster-recovery (DR) site is assumed to exist for backups and is reached over a site-to-site IPsec tunnel.
- Medical devices cannot be patched by the hospital, cannot run a security agent and must not have their firmware or configuration changed by this project. This is consistent with the brief.
- Address ranges in the brief (192.168.10.0/24, .30.0/24, .40.0/24 and host 192.168.20.10) are kept. Addresses for zones the brief does not number are our own choice and are marked as such in Chapter 5.
- The design is vendor-neutral. The laboratory uses OPNsense because it is free and open source; the production recommendation is any NGFW that provides the capabilities listed in Chapter 2.
- Zero Trust architecture and wireless security (WPA2/WPA3 Enterprise) are outside the syllabus anchor for this case and are only referenced where they close a gap.

1.5 Organisation of this report

Part I (Ch. 2–4) covers firewall foundations, threats and risk. Part II (Ch. 5–7) covers architecture, protocols and CIA. Part III (Ch. 8–10) covers the rule base, a critique of the reference design and verification. Part IV (Ch. 11–14) covers the lab, monitoring, incident response and compliance. Chapter 15 concludes.

Part I: Foundations, Threats and Risk

2 Firewall Foundations and Generation Selection

Prepared by: Janhavi Harish Kulkarni **Scope:** Firewall theory, generation selection

2.1 What a firewall is, and what it cannot do

A firewall is a device or software component placed at a network *insertion point* that forwards or drops each flow according to configured policy. The key words here are *insertion point*: a firewall only judges traffic that physically passes through one of its interfaces. Its policy is therefore only as strong as the routing that forces traffic to reach it.

There are three things a firewall fundamentally cannot do:

1. **Protect a host that is already compromised behind it.** Once malware runs on a workstation, every flow that workstation is allowed to make is available to the attacker.
2. **See east-west traffic inside one segment.** Two hosts in the same VLAN are switched directly to each other. Their traffic never reaches a firewall interface.
3. **Help when the path of concern bypasses it.** A 4G modem in a device, a dual-homed workstation, or an unmanaged switch creates a path the firewall never sees.

The incidents at Sanjivani are examples of points 2 and 3. The firewall sits only at the internet edge, so all three incidents happened on paths it could not see. This is why we treat segmentation and firewall placement as a single design problem.

2.2 The access control list

Every filtering firewall, whatever its generation, is driven by an access control list (ACL): an ordered sequence of entries, each consisting of a match condition and an action such as `permit` or `deny`. Generations differ in *what a match may test*, not in the shape of the list.

Two properties of the list decide whether a policy is defensible:

- **Order.** Evaluation is *first match wins*. The firewall stops at the first entry that matches. A broad permit placed above a narrow deny makes the deny unreachable.
- **Breadth.** A narrow entry (one host, one port) expresses a specific requirement. A broad entry (`any`) expresses no requirement at all and grants access nobody asked for.

Listing 2.1: A deny neutered by order

```
permit tcp any any eq 443                ! broad permit placed first
deny   ip  10.61.0.0/24 any              ! vendor deny: never reached for 443
```

In Listing 2.1 a vendor laptop connecting to any internal server on 443 matches the first line and is permitted, so the deny never takes effect. Since order and breadth are properties of the rule list itself, a more expensive firewall would not fix a badly ordered rule base.

2.3 Generation 1: stateless packet filtering

A stateless packet filter evaluates every packet independently against the ACL using only the 5-tuple: source IP, destination IP, protocol, source port and destination port. It is fast, cheap and transparent to applications, but it has **no memory of connections**. Table 2.1 states the consequences as five failures that can each be tested, instead of simply calling the technology outdated.

Table 2.1: The five failures of stateless filtering, with a hospital example

Failure	Why stateless filtering cannot help	Example at Sanjivani
No reasoning about direction	A permit says nothing about replies, so every flow needs a hand-written reverse rule; get the pair wrong and the outage is silent	A nurse's PC reaches the EMR portal only if `permit tcp 192.168.10.21 eq 443 192.168.50.0/23 gt 1023` also exists; written too broadly, the server can open sessions back into the ward
No reasoning about sequencing	A packet claiming an established session is judged on header fields alone	`nmap -sA` (ACK scan) maps which ports the filter passes without completing a handshake
Blind to intent	A legitimate reply and an unsolicited packet with the same 5-tuple look identical; any program can use 443	A host sending from source port 443 reaches any ward port through the "reply" rule (lab E4)
No spoof or out-of-sequence detection	Header fields are the only evidence and the sender controls them	A forged internal source address arriving from outside matches an internal permit
No translation	NAT needs a record of each flow	Internal hosts keep their real addresses and are directly addressable from outside

Summary. All five failures come from one missing property: connection state. The common wrong answer, "it cannot read the payload", is a later limitation that stateful firewalls share.

2.4 Generation 2: circuit-level gateways and application proxies

A **circuit-level gateway (SOCKS)** relays at the TCP-connection level without parsing application data; it needs proxy-aware clients and is largely superseded. An **application-layer proxy** terminates the client connection, parses the protocol, decides on the actual request and opens a separate connection to the server. It gives true protocol enforcement at the cost of latency and one handler per protocol; unsupported protocols cannot be proxied. Mail is the classic case: a proxy can tell SMTP relay between servers (port 25) from client submission (port 587) and judge the envelope. We use a proxy only for research egress (Section 8.5.7).

2.5 Generation 3: stateful inspection

A stateful firewall is a packet filter plus a dynamic **connection state table**. When a packet matches a permit rule, the firewall creates an entry keyed on the 5-tuple and, for TCP, the expected flags and

sequence window. Later packets of the same conversation are validated against that entry. Return traffic passes; unsolicited inbound packets are dropped because no entry exists for them to match.

2.5.1 Tracing one connection through the state table

Figure 2.1 traces a clinical PC opening an HTTPS session to the EMR application server through a stateful firewall.

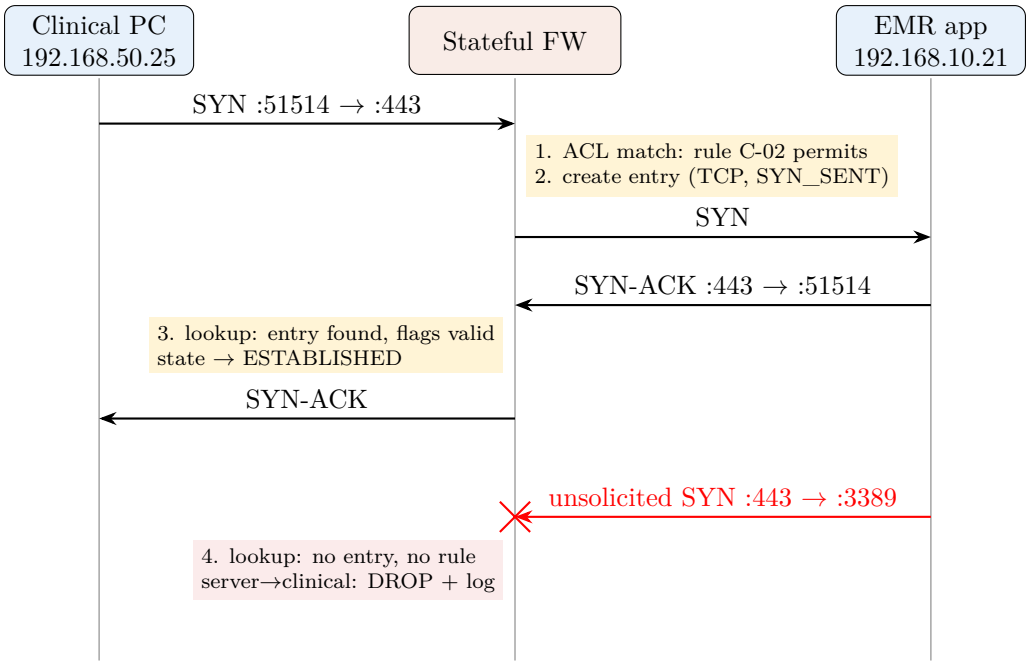


Figure 2.1: A permitted flow creates a state entry; the reply is admitted against it, while an unsolicited packet from the same server is dropped

The unsolicited packet is dropped because there is no entry for it to match. An entry records the 5-tuple, TCP state, sequence window, any NAT translation, an idle timer and the rule that created it. People sometimes say the firewall "learns" a rule, but that is misleading: the table only records connections that a rule has already allowed.

Connectionless protocols and NAT. UDP and ICMP have no handshake, so the first outbound packet creates a *pseudo-state* entry and the reply is admitted against it for a short timeout. A pump's DNS query to 192.168.10.53 therefore needs no reverse rule, unsolicited UDP is still dropped, and late replies after expiry show up as harmless deny noise. NAT/PAT lives in the same table: the outbound source is rewritten and the reply un-translated by lookup, removing Failure 5.

Costs. State costs memory per session and needs timeout tuning for long-lived flows such as HL7 MLLP and idle DICOM associations. State tracking solves direction and sequencing, but it does not give application awareness: a permitted connection to 443 can still carry anything.

2.6 Generation 4: next-generation firewalls

An NGFW is stateful inspection plus a set of content-aware engines. Table 2.2 lists them and what each contributes in this hospital.

2.6.1 The risks introduced by TLS inspection

TLS inspection brings its own risks, which we have to plan for. The interception CA's private key can impersonate any website to every managed PC, so it must sit in an HSM or the firewall's protected key store with audited use. Only clients that trust our CA can be inspected, so guest phones, vendor laptops and medical devices are left alone. Applications that pin certificates will refuse the interception certificate and must go on an exemption list. When inspection fails, users find ways around it, so the failure rate is monitored (Chapter 12). Decrypting staff banking or health traffic raises privacy issues,

Table 2.2: NGFW capabilities and their use at Sanjivani

Capability	What it does	Why the hospital needs it
Application identification	Identifies the application from its on-wire signature, not the port. The port number alone proves nothing.	Detects a tunnel, remote-access tool or file-sharing client hiding on 443 from a research host or a vendor laptop.
URL and path filtering	Permits or denies by hostname, URL category or path.	Patient portal: permit `/portal/`, deny `/admin/` on the same host and port. Guest Wi-Fi: block malware and adult categories.
File-type and anti-malware inspection	Deep packet inspection reads payload content to judge file type and match malware signatures.	Blocks executables and macro documents downloaded into clinical and research zones.
Integrated IPS	Signature and anomaly detection on permitted traffic.	Detects SQL injection against the EMR, exploits against PACS web viewers, and C2 beacons.
User and device identity	Binds policy to a directory user or a managed device instead of an IP address.	Policy follows a clinician between wards; it does not break when DHCP reassigns addresses.
TLS/SSL inspection	Decrypts at the firewall using a locally issued CA certificate, inspects, and re-encrypts to the server.	Without it, the engines above are blind to most traffic, because most traffic is TLS.
Geo-IP and reputation	Deny by country, known-bad ranges or threat-intelligence feeds.	Block inbound management attempts and outbound connections to known C2 infrastructure.

so those categories are exempt (Section 8.5.5). Finally, decryption is CPU-heavy and real throughput is often far below the datasheet figure, which we account for in sizing (Section 5.11).

2.7 Comparison of generations

Table 2.3: Firewall generations compared

Generation	Decision basis	State	App awareness	Latency	Where it fits
Packet filter (stateless)	5-tuple per packet	None	None	Very low	Router ACLs for coarse anti-spoofing; obsolete at the perimeter
Circuit-level gateway	TCP connection	Per connection	None	Low	Legacy proxy-only hosts
Application proxy	Parsed request	Yes	One protocol per handler	High	Mail, explicit web proxy for research egress
Stateful inspection	5-tuple + state table	Dynamic	None	Low	Default baseline; DR site link; lab
NGFW	App + user + URL + payload	Dynamic	Signature, URL, file, reputation	Moderate	Hospital inter-zone and internet edge

2.8 Selecting a generation per requirement

We select a generation from its *decision basis*, not from cost. Table 2.4 applies this to each of the hospital's requirements.

Summary. Stateful inspection is the minimum anywhere in this hospital. NGFW is required at the inter-zone core and the internet edge because four of the eight requirements cannot be met without application, payload or identity awareness.

Table 2.4: Generation selection matrix

Requirement	Minimum generation	Reason from decision basis
Medical devices may reach only DNS, NTP and the interface engine	Stateful	Needs direction (replies only) and default deny; 5-tuple is enough because destinations are fixed hosts. NGFW IPS adds value on 2575.
Radiology must not reach the EMR database	Stateful + NGFW	Address rules stop the path; App-ID confirms MSSQL is the only application used by the permitted PACS broker.
Detect an application tunnelled over 443	NGFW	Only App-ID can classify traffic independently of the port.
Detect exfiltration over TLS	NGFW with TLS inspection	Needs payload visibility and volume baselining per application.
Block attacks on a permitted port (SQL injection against the EMR portal)	NGFW (IPS)	Needs payload signatures; a stateful firewall sees a valid session.
Guest Wi-Fi internet only	Stateful (+ URL filtering)	Direction and default deny suffice; URL categories reduce liability.
Policy that follows a clinician, not an IP	NGFW	Needs directory identity integration.
Remove the `any any` vendor rule	Any (rule-base discipline)	This is an ordering and breadth problem, not a hardware problem.

3 Identification of Security Threats and Attacks

Prepared by: Janhavi Harish Kulkarni **Scope:** Assets, threat actors, STRIDE, attack paths

3.1 Asset register

We begin with what must be protected. Each asset is rated for confidentiality (C), integrity (I) and availability (A) on a 1–3 scale (3 = highest). Patient safety raises integrity and availability for clinical assets above confidentiality.

Table 3.1: Asset register with CIA ratings

Asset	Zone	C	I	A	Why it matters
EMR database (MSSQL)	HIS	3	3	3	All patient records; wrong data causes wrong treatment
EMR app and pharmacy	HIS	3	3	3	Every clinician; wrong drug data harms patients
HL7 interface engine	HIS	2	3	3	Moves orders, results and device data between systems
Billing system	HIS	3	2	2	Holds cardholder data (PCI DSS scope)
Pumps, ventilators, monitors	Devices	1	3	3	Deliver drugs and life support; cannot be patched or run an agent
PACS and modalities	Radiology	3	3	2	All images; modalities often run end-of-life Windows
Directory (AD), DNS, NTP	Core services	2	3	3	Authentication, name resolution and time for every zone

Asset	Zone	C	I	A	Why it matters
Research datasets	Research	3	3	1	Sensitive genomic and trial data; IP value
Patient portal	DMZ	3	2	2	Internet-facing
Backup repository	Management	3	3	3	Last line of defence against ransomware
Firewall and network management	Management	3	3	3	Compromise defeats every other control

3.2 Threat actors

Ransomware operators (financial; enter through phishing, exposed remote access and vendor credentials), opportunistic botnets (recruit any reachable device with internet egress), careless insiders (the personal laptop of F1, the forgotten rule of F3), malicious insiders (record theft), third-party vendors (over-broad or compromised access) and research-data thieves (genomic and trial data).

3.3 Threats identified in the case

Table 3.2 lists the six threats named in the brief, why the current design fails against each, and the MITRE ATT&CK technique that describes the attacker behaviour.

Table 3.2: Threats, current failure and ATT&CK mapping

Threat	How the current design fails	ATT&CK technique
Vendor Wi-Fi lateral movement into clinical systems	The `any any` rule is no barrier	T1133 External Remote Services; T1021 Remote Services
Compromised imaging workstation reaching the EMR on 1433	Flat subnet; east-west traffic never reaches the firewall	T1210 Exploitation of Remote Services; T1078 Valid Accounts
Unauthorised laptop browsing the device VLAN	Access ports not controlled; firewall off-path	T1200 Hardware Additions; T1046 Network Service Discovery
Compromised pump joining a botnet	No egress restriction; device cannot run an agent	T1071 Application Layer Protocol (C2)
Bulk exfiltration over TLS	Stateless filter judges only the 5-tuple	T1048 Exfiltration Over Alternative Protocol; T1041 Exfiltration Over C2 Channel
Application attack on a permitted port	No layer-7 inspection of the request	T1190 Exploit Public-Facing Application

We also add four threats that the brief does not mention: ransomware spreading over SMB and RDP into the server zone (T1021, T1486); compromise of the firewall's own management interface (T1190); DNS tunnelling from the device or research zones, which a plain DNS permit cannot see (T1071.004); and denial of service against the state table (T1499).

3.4 STRIDE analysis per zone

STRIDE classifies threats as Spoofing, Tampering, Repudiation, Information disclosure, Denial of service and Elevation of privilege. Table 3.3 applies it to each zone.

Table 3.3: STRIDE threats per zone

Zone	S	T	R	I	D	E
HIS / EMR	Stolen service account to SQL	Altered prescriptions	Shared DB logins hide who changed a record	Bulk record theft	Ransomware encrypts DB	SQL injection to OS shell
Devices	Rogue host claims a pump's IP	Modified HL7 dose message	Devices keep no audit log	Patient data in clear HL7	Broadcast storm drops monitors	Default vendor passwords
Radiology	Fake modality sends to PACS	Altered images	Shared workstation logins	DICOM in clear text	PACS storage filled	Old Windows on modalities
Clinical	Phished clinician credentials	Malware edits local files	Generic ward logins	Screen and print leakage	Ransomware on PCs	Local admin rights
Guest / vendor	Evil-twin SSID	Traffic manipulation on open Wi-Fi	Anonymous guests	Sniffing other guests	Bandwidth exhaustion	Pivot through `any any`
Research	Collaborator accounts reused	Altered trial data	Shared compute accounts	Genomic data exfiltration	Crypto-mining on compute	Unpatched instrument PCs
Management	Admin credential theft	Rule-base tampering	Changes without operator identity	Config backups leaked	Firewall DoS	Web GUI exploit

3.5 Attack paths for the three incidents

Table 3.4: How each incident worked, and where the new design breaks it

Incident	Path on the current network	Broken by (new design)
F1 Rogue laptop on device port	Gets a DHCP address in the device VLAN, ARP-scans it, opens device web and telnet services, and routes anywhere because the network is flat	802.1X/MAB puts unknown MACs in quarantine VLAN 999; PVLAN isolation; device rules allow only DNS, NTP and MLLP; "new MAC" SIEM alert
F2 Radiology workstation to EMR DB	Phished workstation scans the flat network, finds TCP 1433 on 192.168.10.20 and tries harvested credentials	Separate zones force the path through the NGFW; no radiology host may reach 1433 (our correction, Ch. 9); the deny raises a critical alert
F3 Vendor Wi-Fi to clinical	Vendor laptop, possibly infected elsewhere, reaches anything through `permit any any`	Rule deleted; vendor Wi-Fi is internet-only; maintenance only through a time-bound IPsec tunnel to a recorded jump host with ticket-bound rules

3.6 What the firewall still cannot stop

A compromised device attacking a peer in its own VLAN (needs PVLAN isolation); a malicious payload inside a valid HL7 message on 2575 (needs interface-engine validation); a clinician with legitimate access copying records (needs EMR audit and DLP); attacks inside pinned TLS sessions (needs endpoint controls); and the vulnerability of an unpatchable device itself, since the firewall only limits who can reach it.

4 Security Risk Identification and Analysis

Prepared by: Janhavi Harish Kulkarni **Scope:** Risk method, risk register, heat maps

4.1 Method

We use a qualitative 5×5 matrix. Likelihood (L) and impact (I) are each scored 1–5, and risk $R = L \times I$. Bands are: 1–4 Low, 5–9 Medium, 10–16 High, 20–25 Critical. Impact scoring gives patient harm the highest weight, followed by regulatory exposure, data loss and downtime.

Likelihood runs from 1 (rare: no known path) to 5 (almost certain: already observed); impact from 1 (negligible) to 5 (patient harm or hospital-wide outage).

4.2 Risk register

Each risk is scored twice: *inherent* on the current flat network, and *residual* after the controls in this report.

Table 4.1: Risk register (inherent and residual)

ID	Zone pair	Threat	L	I	R	Control	Res.
R1	Vendor Wi-Fi → clinical	Lateral movement on old `any any` path	5	4	20	Rule deleted; default deny; internet-only vendor SSID; deny-rate alert	4
R2	Radiology → HIS	Workstation reaches EMR on 1433	4	5	20	No radiology host to 1433; PACS broker to MLLP only; IPS	4
R3	Device → internet	Pump joins botnet or phones home	3	4	12	Three named flows only; deny all egress; DNS inspection	3
R4	Rogue host → device	Unauthorised laptop on device port	5	4	20	802.1X/MAB; quarantine VLAN; new-MAC alert	4
R5	Guest Wi-Fi → internal	Rogue device reaching clinical services	4	3	12	No route; client isolation; denies logged	2
R6	Research → HIS	Research traffic reaching clinical data	3	4	12	Separate zone; no permit to HIS; de-identified extracts via SFTP drop	3
R7	Device ↔ device	Compromised device attacks peers	2	5	10	Private VLAN isolation; peer-to-peer deny	5
R8	Clinical → internet	Bulk exfiltration over TLS	3	4	12	TLS inspection; App-ID; per-zone volume baseline	6
R9	Internet → DMZ	Attack on portal via 443	4	4	16	IPS; URL path rules; WAF profile	6
R10	Clinical → HIS	Ransomware spreads via SMB/RDP	4	5	20	Only HTTPS to EMR app; no SMB/RDP to servers; IPS	8
R11	Any → management	Firewall GUI compromised	2	5	10	Management only from bastion; MFA; separate interface	3

ID	Zone pair	Threat	L	I	R	Control	Res.
R12	NGFW itself	TLS CA key stolen	2	5	10	HSM key store; access audit; CA rotation	4
R13	Edge	State-table exhaustion DoS	3	4	12	Per-source session limits; SYN cookies; HA pair	6
R14	Rule base	Drift back to `any any`	4	4	16	Quarterly any-any search; expiring exceptions; change control	4

4.3 Risk heat maps

Figures 4.1 and 4.2 place each risk on the likelihood–impact grid before and after the redesign. Residual likelihood and impact were re-scored per risk during the team's review, after the laboratory results in Part IV; the residual score in Table 4.1 is their product.

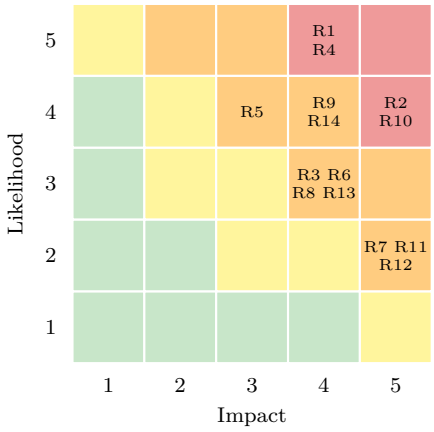


Figure 4.1: Inherent risk

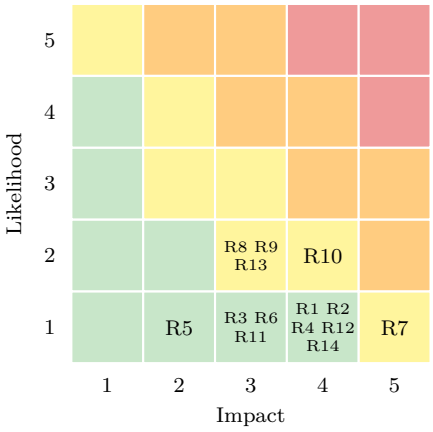


Figure 4.2: Residual risk

4.4 Discussion

Four risks start in the critical band (R1, R2, R4, R10), and three of these are the original incidents. After the redesign nothing is above Medium. The remaining Medium risks (R7, R8, R9, R10, R13) all involve traffic that is either permitted or never reaches the firewall, so they are reduced rather than removed and become the focus of Part IV. R7, a device attacking its neighbour, stays the most serious because the firewall cannot see that traffic at all; this is why our response plan isolates one device at a time instead of the whole zone (Chapter 13).

Part II: Architecture, Protocols and CIA

5 Network Architecture and Segmentation

Prepared by: Debapriya Kundu **Scope:** Zone model, IP plan, firewall placement, access layer

5.1 Design principles

(1) Every inter-zone flow crosses the NGFW: the core carries zone VLANs at layer 2 only and each zone's gateway is a firewall interface. (2) A zone groups hosts with the same trust level and the same required flows. (3) High-volume, low-risk traffic (imaging) stays inside one zone. (4) Controls a firewall cannot provide sit at the access layer. (5) The management plane is separate, reachable only from a bastion. (6) No change to medical-device firmware or configuration.

5.2 Current architecture

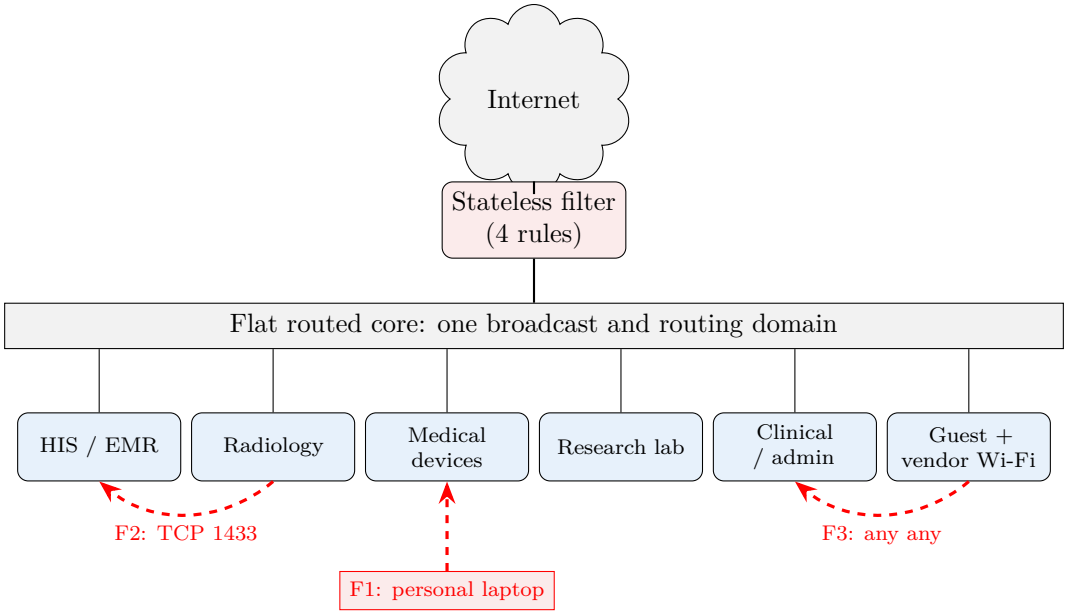


Figure 5.1: Current state: flat network with an edge-only stateless filter. All three incidents (red) occur on paths the firewall never sees.

5.3 Zone model

We divide the estate into ten zones plus an unrouted quarantine VLAN. Zones 9 and 10 do not appear in the brief; we add them because vendor access and network management both need a defined home (see Chapter 9).

5.4 VLAN and IP addressing plan

Ranges marked * are kept from the case brief; the rest are our allocation.

5.5 Proposed architecture

5.5.1 Two firewall tiers and forced routing

The **edge NGFW pair** handles the internet link, DMZ, vendor IPsec and the DR tunnel, doing NAT, URL filtering, outbound TLS inspection and IPS on portal traffic. The **internal segmentation firewall (ISFW) pair** is the default gateway of every internal zone, with each VLAN as a sub-interface on an LACP trunk from the core, and enforces inter-zone policy, App-ID and IPS. Two tiers mean an

Table 5.1: Security zones and trust levels

#	Zone	Trust	Contents	Business owner
1	HIS	High	EMR DB and app, pharmacy, billing, interface engine, AD, DNS, NTP, de-identification server	Head of IT
2	DMZ	Low	Patient portal reverse proxy, outbound mail relay, research web proxy	Head of IT
3	DEVICES	Restricted	Infusion and syringe pumps, ventilators, patient monitors	Biomedical engineering
4	RADIOLOGY	Medium	CT, MRI, ultrasound, PACS, PACS broker, reading workstations	Head of radiology
5	CLINICAL	Medium	Nurses' stations, doctors, registration, HR, biomedical engineering PCs	Nursing director
6	GUEST	Untrusted	Visitor Wi-Fi	Facilities
7	VENDOR-WIFI	Untrusted	Vendor and medical-engineer laptops	Procurement
8	RESEARCH	Medium	Assay instruments, bioinformatics compute, SFTP drop	Research director
9	VENDOR-MAINT	Low	IPsec landing pool and recorded jump host	Biomedical engineering
10	MGMT	Highest	Firewall management, bastion, SIEM, syslog, backup, NMS	Head of IT security
–	QUARANTINE	None	Unauthenticated ports; no route anywhere	Network team

Table 5.2: VLAN and IP plan

Zone	VLAN	Subnet	Gateway	Notes
HIS	10	192.168.10.0/24*	.1	Static addressing only
DMZ	20	192.168.20.0/24*	.1	Portal at .10*
DEVICES	30	192.168.30.0/24*	.1	PVLAN isolated; DHCP reservations per MAC
RADIOLOGY	40	192.168.40.0/24*	.1	Modalities static; workstations DHCP
CLINICAL	50	192.168.50.0/23	.1	510 hosts; 802.1X role-assigned
GUEST	60	10.60.0.0/22	.1	1 022 hosts; client isolation; 4 h lease
VENDOR-WIFI	61	10.61.0.0/24	.1	Client isolation; registration portal
RESEARCH	70	192.168.70.0/24	.1	Proxy-only egress
VENDOR-MAINT	80	192.168.80.0/24	.1	Jump host .10; IPsec pool .128/25
MGMT	90	192.168.90.0/24	.1	Out-of-band switch fabric
QUARANTINE	999	none	none	No layer-3 interface exists
DR site	–	10.200.0.0/24	–	Reached over site-to-site IPsec

Table 5.3: Named hosts referenced by the rule base

Object	Address	Role	Object	Address	Role
H_EMR_DB	192.168.10.20*	EMR database, MSSQL 1433	H_PROXY	192.168.20.40	Explicit web proxy for research egress
H_EMR_APP	192.168.10.21	EMR application, HTTPS 443	H_PACS	192.168.40.10	PACS server (DICOM 104 / DICOM-TLS 2762)
H_PHARMACY	192.168.10.30	Pharmacy application, HTTPS 443	H_PACS_ARCH	192.168.40.11	PACS archive
H_BILLING	192.168.10.35	Billing application, HTTPS 443	H_PACS_ BROKER	192.168.40.12	RIS/PACS broker; HL7 to interface engine
H_IFENGINE	192.168.10.40*	HL7 interface engine, MLLP 2575	H_SFTP_DROP	192.168.70.250	Research SFTP drop for de-identified data
H_DNS	192.168.10.53*	Internal resolver	H_JUMP	192.168.80.10	Vendor jump host with session recording
H_NTP	192.168.10.57*	Internal time server (stratum 2)	H_BASTION	192.168.90.5	Administrator bastion
H_AD	192.168.10.60	Directory: LDAPS 636, Kerberos 88	H_SIEM	192.168.90.10	SIEM and syslog-TLS collector
H_DEID	192.168.10.70	De-identification server for research extracts	H_BACKUP	192.168.90.20	Backup server
H_PORTAL	192.168.20.10*	Patient portal reverse proxy	H_NMS	192.168.90.30	Network monitoring (SNMPv3)
H_MAILRELAY	192.168.20.25	Outbound SMTP relay	H_DR_BACKUP	10.200.0.10	Off-site backup target

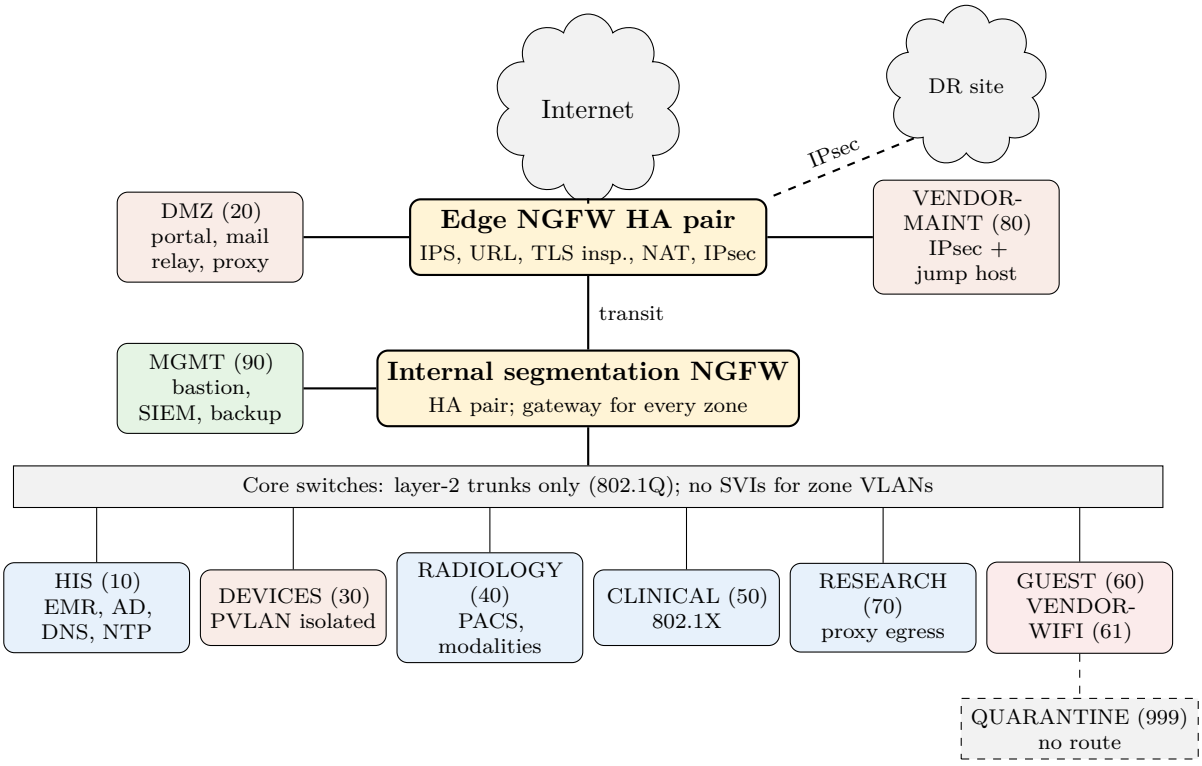


Figure 5.2: Proposed architecture: ten zones; every inter-zone and internet flow is routed through an NGFW pair

internet-edge problem cannot affect clinical traffic between internal zones; on a smaller budget both roles can run on one HA pair with virtual systems without changing the zone model.

To make sure nothing bypasses the firewall, zone VLANs have no SVI on the core, the core switches have no route between user VLANs, DHCP relay runs on the ISFW, and dual-homed hosts are not allowed (modalities with vendor 4G modems are inventoried and the modems disabled or brought under the vendor access process).

5.6 Access-layer controls

These controls close the gaps that a firewall cannot see (Chapter 2): the rogue laptop (F1) and peer-to-peer attacks inside a zone.

Table 5.4: Access-layer hardening standard

Control	Configuration	Threat closed
802.1X (EAP-TLS)	Managed PCs authenticate with a machine certificate; RADIUS assigns the VLAN by role	Unknown laptops in clinical zone
MAC Authentication Bypass with profiling	Devices that cannot do 802.1X are allow-listed by MAC from the biomedical asset register and profiled (DHCP fingerprint, OUI)	F1 rogue laptop on a device port
Quarantine VLAN 999	Any port failing authentication lands here; no layer-3 interface exists	F1; unknown devices
Private VLAN (isolated)	Device ports are isolated; only the promiscuous uplink to the firewall is reachable	R7 device-to-device attack
Port security	Maximum one MAC on device ports; violation shuts the port and alerts	MAC flooding; hub insertion
DHCP snooping, DAI, IP Source Guard	Bind IP to MAC to port; drop forged ARP and spoofed sources	Spoofing; ARP man-in-the-middle
BPDU guard, storm control	Shut ports that send BPDUs; cap broadcast at 1%	Loops and broadcast storms dropping monitors
Unused ports	Administratively down, placed in VLAN 999	Opportunistic access

5.7 Wireless mapping

SJV-STAFF (WPA3-Enterprise, EAP-TLS) maps to CLINICAL by RADIUS role; SJV-MED (WPA2-Enterprise or per-device PSK, MAC allow-list) maps to DEVICES; SJV-GUEST (captive portal with SMS one-time password, client isolation, rate-limited) maps to GUEST; SJV-VENDOR (WPA3-Personal rotated monthly, portal registration) maps to VENDOR-WIFI and is internet-only — no maintenance is done from it.

5.8 Vendor access design

In the old setup vendors had standing access through their VLAN. In our design a vendor has no access at all until a ticket is raised. Biomedical engineering raises a ticket naming the engineer, device, ports and a window of at most 4 hours. The vendor's IKEv2 account (certificate plus one-time password) is enabled for that window only and lands in 192.168.80.128/25, whose only destination is the recorded jump host H_JUMP. From there a scheduled rule carrying the ticket number reaches the named device and port, and expires automatically. Recordings are kept for 180 days.

5.9 Management plane

All management interfaces live only in MGMT (90) on an out-of-band switch. Administrators reach it only through H_BASTION with SSH keys or HTTPS plus MFA; no user zone has a route to it; every configuration change is logged to H_SIEM with operator identity and a before/after diff.

5.10 High availability and failure behaviour

Both firewall tiers are active/passive pairs with state synchronisation, so a failover does not drop established HL7 or DICOM sessions. We decide the failure mode per path, because "fail-open" trades confidentiality for availability and the right trade differs by zone.

Table 5.5: Failure behaviour per path

Path	Mode	Reason
Inspection engines (IPS, TLS) on the internet edge	Fail-open	If the inspection engine fails, traffic continues under the stateful policy. Teleradiology and e-prescribing must not stop because a signature update failed.
Inspection engines on internal zone pairs	Fail-open to stateful	The stateful rule base still enforces zone isolation; only content inspection is lost, and that loss is alerted.
Whole internal firewall (both units down)	Fail-closed	Opening all zones to each other would recreate the flat network. Clinical continuity is protected by HA, not by bypass.
Device zone flows	Fail-closed	Devices continue to operate standalone; pumps keep running their programmed infusions without the EMR.

5.11 Platform sizing

Sizing uses throughput *with all inspection enabled*, never the datasheet firewall figure. For about 3 500 endpoints we estimate peaks of 0.8 Gbit/s at the edge with TLS inspection, 3 Gbit/s internal threat-prevention throughput, 400 000 concurrent sessions and 15 000 new sessions per second, and specify 50% headroom on each (1.2 Gbit/s, 4.5 Gbit/s, 600 000 and 22 500). Imaging does not cross the ISFW because modalities, PACS and reading workstations share a zone.

5.12 Phased migration

Weeks 0–2: install the HA pairs and move gateways zone by zone (GUEST first, DEVICES last), each zone ending in an *allow and log* rule. Weeks 2–4: two weeks log-only, comparing observed flows with the rule base and adding missing legitimate flows through change control. Week 4: replace each *allow and log* with *deny and log*, one zone per night, with timed rollback. Weeks 5–8: IPS in alert mode then block; TLS inspection for CLINICAL, then RESEARCH.

6 Selection of Appropriate Secure Protocols

Prepared by: Debapriya Kundu **Scope:** Protocol register, insecure protocol retirement

6.1 Protocol register

Every flow permitted by the rule base must use a protocol on this register. A protocol that is not on it is not permitted, which is the protocol-level equivalent of default deny.

Table 6.1: Secure protocol register

Function	Protocol	Port	Policy consequence
Imaging	DICOM upper layer; DICOM over TLS; DICOMweb	104, 2762, 443	Permitted only to named PACS nodes. TLS (2762) required for any DICOM leaving the radiology zone.
Clinical messaging	HL7 v2 over MLLP	2575	Restricted to the interface engine. MLLP has no encryption, so it is confined to two hosts per flow and wrapped in TLS where the endpoint supports it.

Function	Protocol	Port	Policy consequence
Web and portal	HTTPS, TLS 1.2 and 1.3	443	Clear-text HTTP removed. TLS 1.0/1.1 and CBC-mode suites disabled on the portal.
Directory	LDAPS; Kerberos	636; 88	Clear-text LDAP binds (389) blocked from user zones.
Name resolution	DNS with DNSSEC validation	53	Only H_DNS answers internal clients; outbound DNS from other hosts and DNS-over-HTTPS to public resolvers are blocked.
Time	NTP with symmetric keys or NTS	123 (4460 for NTS-KE)	Devices sync only to H_NTP; H_ NTP syncs to authenticated upstream servers.
Monitoring	SNMPv3 authPriv (SHA-256, AES-128)	161	No v1/v2c community strings anywhere.
Logging	Syslog over TLS	6514	Logs are confidential and tamper-evident in transit.
Administration	SSH v2 with keys	22	Only from H_BASTION; password login disabled.
Vendor access	IPsec IKEv2 (AES-GCM-256, DH group 19/20)	UDP 500, 4500	Rules target the tunnel pool, not a standing VLAN.
Site-to-site backup	IPsec IKEv2 to DR site	UDP 500, 4500	Backup data encrypted in transit and at rest.
File transfer	SFTP	22	FTP removed. Research extracts arrive only by SFTP.
Mail	SMTP with STARTTLS (relay); submission	25, 587	Only H_MAILRELAY sends to the internet on 25.

6.2 Protocol notes and retired protocols

Classic DICOM (104) and HL7 MLLP (2575) have no security of their own and cannot be changed on legacy devices, so they are protected by *scoping*: DICOM 104 never leaves the radiology zone, and each device may open MLLP only to the interface engine, whose state timeout is raised to 24 hours so idle connections are not cut. Permitting DNS to H_DNS is safe only because the resolver logs every query and blocks malicious domains; long, high-entropy names from DEVICES are alerted as possible tunnelling. Accurate time underpins log correlation, Kerberos and certificate checks, so devices use only the internal NTP server.

Retired: Telnet (23) → SSH; FTP (21) → SFTP; HTTP (80) → HTTPS (80 only redirects); SNMPv1/v2c → SNMPv3; LDAP simple bind (389) → LDAPS; SMBv1 → SMBv3 inside HIS only; RDP from user zones → bastion only.

7 Protection of Confidentiality, Integrity and Availability

Prepared by: Debapriya Kundu **Scope:** CIA analysis per zone

7.1 Confidentiality

Confidentiality is now *zone-scoped*. Guest and vendor segments have no route to clinical or device zones. Research data is separated from the EMR, and research receives only de-identified extracts pushed from H_DEID. Within permitted flows, confidentiality relies on the protocols in Chapter 6:

TLS for web and portal, LDAPS for directory, IPsec for vendor and DR traffic, and syslog over TLS for logs. Where a protocol is clear text and cannot be changed (DICOM 104, MLLP), confidentiality is preserved by confining it to the smallest possible set of hosts.

7.2 Integrity

Integrity is defended twice. First, default deny blocks every flow that has no stated requirement, so an attacker cannot reach a system to tamper with it. Second, application and IPS inspection reject a malicious request even when it arrives on a permitted port, for example an SQL injection string inside an HTTPS request to the portal. On the access layer, DHCP snooping and dynamic ARP inspection prevent a host from impersonating another on the same segment.

7.3 Availability

Availability leads the brief, because in a hospital an outage can harm a patient. It is protected by HA with state synchronisation on both tiers, explicit failure behaviour per path (Table 5.5), sizing with 50% headroom, two weeks of log-only operation before enforcement, no change to device firmware, keeping imaging inside one zone, and per-source session limits so one infected host cannot exhaust the state table.

7.4 CIA by zone

Table 7.1: How each zone's CIA requirement is met

Zone	Confidentiality	Integrity	Availability
HIS	Only named apps reach named servers; no user zone reaches 1433	IPS on EMR traffic; change-controlled rules	HA; backup out to DR
DEVICES	MLLP confined to interface engine	PVLAN; DAI; three flows only	Fail-closed is safe; devices run standalone
RADIOLOGY	DICOM 104 stays in zone; TLS when leaving	Modalities only to PACS	Imaging does not load the ISFW
CLINICAL	TLS inspection; DLP alerts	IPS; file blocking	Bandwidth guarantees for EMR app
GUEST / VENDOR-WIFI	No internal route; client isolation	–	Rate limits so guests cannot starve clinical
RESEARCH	Proxy egress; inspected uploads	SFTP integrity checks	Lower priority
MGMT	Bastion only; MFA	Config diffs logged	OOB network survives data-plane outage

7.5 Implementation and readiness validation

Implementation (11.2-11.4): VirtualBox 7.2.22, OPNsense 25.7, four Alpine 3.20.10 VMs; reboot verified.

Table 7.2: Software and policy checks

Validation check	Observed
Unit tests: Part II / full suite	9 / 42 PASS
Objects and policy lint	PASS
Simulator probes / lab rules	30 / 18 PASS
Local service checks (loopback)	6 / 6 PASS
Policy / temporary setup rules	18 / 0
Blocked flows matched in PF log	7 / 7 PASS

Table 7.3: VM readiness checks

Lab role	Checks	Observed
MGMT bastion	6	PASS
HIS VM	7	PASS
Device VM	8	PASS
Radiology VM	8	PASS
Vendor VM	6	PASS
Total readiness	**35**	**PASS**

The 7 block checks are included in the 35. E1-E8 remain separate. IPS/App-ID, NAC/PVLAN and HA are unverified. EMR uses plaintext HTTP on 443; the database is a TCP stand-in.

Evidence: part2_architecture_protocols/execution/results/ (offline, local_services and readiness records).

Part III: Rule Base, NGFW Policy and Verification

8 Rule-Base Design and NGFW Policy

Prepared by: Vedhesh Dhinakaran **Scope:** Object model, complete rule base, inspection profiles

8.1 Disciplines that make a rule base defensible

Table 8.1: Design principles and how they are expressed

Principle	Expression in our rule base	Failure it prevents
Default deny	A logged `deny any` closes every zone section, plus a global final deny (X-99)	Implicit access when a VLAN is added
Explicit allow	Every permit names a host or group, a service, an owner and a requirement	Rules nobody can explain
First match wins	Global denies on top; specific permits above general ones; zone deny last	A broad rule above a deny neutering it
Bidirectional as state	Permit the forward flow only; returns admitted by the state table and documented in the Return column	A return rule opening a new inbound path
Identity over address	Clinical rules bind to directory groups (`GRP_CLINICIANS`, etc.)	Policy breaking when DHCP reassigns an address
Least-privilege egress	DEVICES and RADIOLOGY have no internet rule at all	A compromised pump phoning home
Expiring exceptions	Vendor rules are scheduled and carry a ticket and an end date	Drift back towards `any any`
Log every decision	Every deny and every permit logs the 5-tuple, rule ID and (for NGFW) app and user	Incidents that cannot be reconstructed

8.2 Object model, naming and rule metadata

We never put raw IP addresses in rules. Every rule refers to named objects so that a reviewer can read it like a sentence, and moving a host means editing one object instead of many rules. The prefixes are `Z_` zone, `N_` network, `H_` host, `G_` host group, `S_` service, `A_` application (App-ID), `GRP_` directory group, `F_` FQDN and `SCH_` schedule. Two service groups are used often: `S_CORE` (DNS on UDP/TCP 53, NTP on UDP 123, Kerberos 88 and LDAPS 636) and `S_CORE_MIN` (DNS and NTP only). `S_WEB` is TCP 443, TCP 80 and UDP 443.

Each rule carries a stable **ID** that is never reused, an **owner** (IT, SEC, BIO biomedical, RAD radiology, NUR nursing, FIN finance, RES research, FAC facilities), the **requirement** it serves, a **review** cycle (Q quarterly, M monthly, T expires with its ticket) and a **log** setting (every rule logs; **A** means a hit raises a SIEM alert). The exact review date, ticket and creation date are stored in the rule description and exported with the policy.

8.3 Complete rule base

Rules are evaluated top to bottom; the first match wins. Returns are admitted by the state table for every permit (Section 8.4).

Table 8.2: Complete NGFW rule base (first match wins)

ID	Source	Destination	Service / App	Action	Log	Owner	Requirement	Rev.
Section 0 — Global protections (evaluated first)								
G-01	Threat-intel and geo blocklists	any	any	deny	A	SEC	Drop known-bad sources and destinations before any permit	Q
G-02	all zones except Z_MGMT	Z_MGMT	any	deny	A	SEC	Management plane unreachable from user zones	Q
G-03	any not Z_HIS	H_EMR_DB	any	deny	A	IT	No zone outside HIS ever reaches the EMR database (incident F2)	Q
G-04	any except H_ DNS, H_PROXY	internet	DNS, DoT (853), A_DOH	deny	A	SEC	Stop DNS bypass and DNS tunnelling	Q
Section 1 — Management (Z_MGMT)								
M-01	H_BASTION	firewall, switch, AP mgmt IPs	SSH, HTTPS	permit	yes	SEC	Administration only from bastion	Q
M-02	H_BASTION	Z_HIS, Z_DMZ, Z_RESEARCH servers	SSH, RDP	permit	yes	IT	Server administration	Q
M-03	H_NMS	Z_HIS, Z_DMZ servers	SNMPv3 (udp/161)	permit	yes	IT	Health monitoring	Q
M-04	Z_HIS, Z_DMZ, Z_RESEARCH, H_JUMP	H_SIEM	syslog-TLS (tcp/6514)	permit	yes	SEC	Central logging	Q
M-05	H_BACKUP	H_DR_ BACKUP (via IPsec)	S_BACKUP	permit	yes	IT	Off-site backup copy	Q
M-06	H_BASTION, H_SIEM	internet	HTTPS, URL cat. “software updates”	permit	yes	SEC	Patches and signature updates	Q
M-07	Z_MGMT	any	any	deny	A	SEC	MGMT default deny	Q
Section 2 — HIS (Z_HIS)								
H-01	Z_HIS servers	H_BACKUP	S_BACKUP	permit	yes	IT	“Backup out” (brief)	Q
H-02	H_EMR_APP, H_IFENGINE	F_ EPRESCRIBE, F_ LABPARTNER	HTTPS, App-ID ssl	permit	yes	IT	E-prescribing and external lab results	Q
H-03	Z_HIS servers	H_MAILRELAY	SMTP (tcp/25)	permit	yes	IT	Application notifications	Q
H-04	H_DEID	H_SFTP_DROP	SFTP (tcp/22)	permit	yes	RES	De-identified extracts pushed to research	Q
H-05	H_IFENGINE	H_PACS_ BROKER	S_MLLP (tcp/2575)	permit	yes	RAD	Orders sent to radiology	Q
H-06	H_NTP	NPL / NIC NTP servers	udp/123	permit	yes	IT	Upstream time traceable to Indian standard time (CERT-In)	Q
H-07	H_DNS	internet	DNS	permit	yes	IT	Recursive resolution	Q
H-08	Z_HIS	any	any	deny	A	IT	HIS default deny	Q
Section 3 — DMZ and internet inbound								
D-01	internet	H_PORTAL	HTTPS, URL path `/admin/*`	deny	A	IT	Admin path never public	Q
D-02	internet	H_PORTAL	HTTPS, URL path `/portal/*`, IPS strict	permit	yes	IT	Patient portal	Q
D-03	H_PORTAL	H_EMR_APP	HTTPS (API)	permit	yes	IT	Portal back end	Q
D-04	H_MAILRELAY	internet	SMTP (tcp/25)	permit	yes	IT	Outbound mail	Q
D-05	H_PROXY	internet	S_WEB, TLS inspection, file and DLP profiles	permit	yes	RES	Research inspected egress	Q
D-06	internet (DR and vendor IKE peers)	edge IPsec gateway	udp/500, udp/4500	permit	yes	SEC	Vendor and DR tunnels	Q
D-07	Z_DMZ	any	any	deny	A	IT	DMZ default deny	Q
D-08	internet	any	any	deny	yes	SEC	Inbound default deny	Q
Section 4 — Medical devices (Z_DEVICES)								
DV-01	Z_DEVICES	H_DNS	DNS (udp/53, tcp/53)	permit	yes	BIO	Name resolution	M
DV-02	Z_DEVICES	H_NTP	NTP (udp/123)	permit	yes	BIO	Time	M

continued on next page

ID	Source	Destination	Service / App	Action	Log	Owner	Requirement	Rev.
DV-03	Z_DEVICES	H_IFENGINE	S_MLLP, App-ID A_HL7, IPS	permit	yes	BIO	Device data to EMR	M
DV-04	Z_DEVICES	Z_DEVICES	any	deny	A	BIO	No peer traffic (with PVLAN)	M
DV-05	Z_DEVICES	any	any	deny	A	BIO	Strict egress default	M
Section 5 — Radiology (Z_RADIOLOGY)								
R-01	Z_RADIOLOGY	G_CORE	S_CORE	permit	yes	RAD	DNS, time, logon	Q
R-02	H_PACS_ BROKER	H_IFENGINE	S_MLLP, App-ID A_HL7	permit	yes	RAD	Results and status to EMR	Q
R-03	GRP_ RADIOLOGISTS	H_EMR_APP	HTTPS, App-ID emr-web	permit	yes	RAD	Clinical context while reporting	Q
R-04	H_PACS_ARCH	H_DR_ BACKUP	DICOM-TLS (tcp/2762)	permit	yes	RAD	Off-site image copy	Q
R-05	H_PACS	F_TELERAD	DICOM-TLS, DICOMweb (443)	permit	yes	RAD	Teleradiology	Q
R-06	Z_RADIOLOGY	any	any	deny	A	RAD	Radiology default deny (incl. internet)	Q
Section 6 — Clinical and admin (Z_CLINICAL)								
C-01	Z_CLINICAL	G_CORE	S_CORE	permit	yes	NUR	DNS, time, logon	Q
C-02	GRP_ CLINICIANS	H_EMR_APP	HTTPS, App-ID emr-web, IPS	permit	yes	NUR	EMR access	Q
C-03	GRP_ PHARMACISTS	H_PHARMACY	HTTPS	permit	yes	NUR	Pharmacy system	Q
C-04	GRP_BILLING	H_BILLING	HTTPS	permit	yes	FIN	Billing (PCI scope)	Q
C-05	GRP_ CLINICIANS	H_PACS	DICOMweb viewer (443)	permit	yes	RAD	Images at the bedside	Q
C-06	GRP_BIOMED	H_JUMP	RDP (tcp/3389)	permit	yes	BIO	Device maintenance via jump host	Q
C-07	Z_CLINICAL	internet	S_WEB, URL filtering, TLS insp., file blocking, IPS	permit	yes	NUR	Internet (brief)	Q
C-08	Z_CLINICAL	any	any	deny	A	NUR	Clinical default deny	Q
Section 7 — Guest and vendor Wi-Fi								
GW-01	Z_GUEST	N_RFC1918	any	deny	yes	FAC	No internal reach	Q
GW-02	Z_GUEST	internet	S_WEB, DNS; URL filtering; 5 Mbit/s per client	permit	yes	FAC	Internet only (brief)	Q
GW-03	Z_GUEST	any	any	deny	yes	FAC	Guest default deny	Q
VW-01	Z_VENDOR_ WIFI	N_RFC1918	any	deny	A	SEC	Replaces the old `any any` (incident F3)	Q
VW-02	Z_VENDOR_ WIFI	internet	S_WEB, DNS, IPsec (to own company); URL filtering	permit	yes	SEC	Internet only (brief)	Q
VW-03	Z_VENDOR_ WIFI	any	any	deny	A	SEC	Vendor Wi-Fi default deny	Q
Section 8 — Research (Z_RESEARCH)								
RS-01	Z_RESEARCH	H_DNS, H_NTP	S_CORE_MIN	permit	yes	RES	DNS and time	Q
RS-02	Z_RESEARCH	H_PROXY	tcp/3128	permit	yes	RES	Inspected egress via proxy (brief)	Q
RS-03	Z_RESEARCH	Z_HIS	any	deny	A	RES	Research never reaches clinical data	Q
RS-04	Z_RESEARCH	any	any	deny	A	RES	Research default deny	Q
Section 9 — Vendor maintenance (Z_VENDOR_MAINT)								
VM-01	IPsec pool 192.168.80.128/25	H_JUMP	RDP, SSH; schedule SCH_ *ticket*	permit	yes	BIO	Vendor reaches jump host only during ticket window	T
VM-02	H_JUMP	named device IP	named vendor port; schedule SCH_*ticket*	permit	A	BIO	Template: created per ticket, disabled otherwise	T
VM-03	Z_VENDOR_ MAINT	any	any	deny	A	BIO	Vendor default deny	Q
Final rule								
X-99	any	any	any	deny	A	SEC	Global default deny; any hit means a zone section is incomplete	Q

The rule base has 60 entries: four global protections, 44 zone-specific permits and denies, eleven zone and inbound default denies that duplicate the final rule on purpose (so that each zone has its own deny counter), and the final rule X-99. G-03 duplicates what the zone defaults already achieve; we keep it so the EMR database has its own counter and alert, because it is the asset that was reached in incident F2.

8.4 How return traffic is admitted

Every permit above is a forward rule. On the stateful NGFW, the state table admits the reply: TCP flows are flag- and sequence-validated, and DNS and NTP get pseudo-state entries. No rule permits a destination to open a new session back to its source. For audit, the vendor-neutral listings below also write the return dependency explicitly with `established`, as the case brief recommends. These entries make the dependency visible to a reviewer and would still hold if the same policy were ever enforced by a stateless device, where the UDP replies would additionally need to be enumerated.

Listing 8.1: Medical-device zone in generic ACL syntax

```
! ---- Z_DEVICES (192.168.30.0/24): three named flows, then deny ----
permit udp 192.168.30.0/24 host 192.168.10.53 eq 53          ! DV-01 DNS
permit tcp 192.168.30.0/24 host 192.168.10.53 eq 53          ! DV-01 DNS over TCP (large/DNSSEC
    replies)
permit udp 192.168.30.0/24 host 192.168.10.57 eq 123         ! DV-02 NTP
permit tcp 192.168.30.0/24 host 192.168.10.40 eq 2575        ! DV-03 HL7 MLLP to interface engine
permit tcp host 192.168.10.40 eq 2575 192.168.30.0/24 established  ! reply only, never a new session
permit tcp host 192.168.10.53 eq 53 192.168.30.0/24 established    ! reply only
deny   ip  192.168.30.0/24 192.168.30.0/24 log               ! DV-04 no peer traffic
deny   ip  192.168.30.0/24 any log                           ! DV-05 strict egress default
```

Listing 8.2: Radiology zone, corrected from the case brief

```
! ---- Z_RADIOLOGY (192.168.40.0/24) ----
deny   tcp 192.168.40.0/24 host 192.168.10.20 eq 1433 log    ! G-03: no radiology host to EMR SQL
permit tcp host 192.168.40.12 host 192.168.10.40 eq 2575     ! R-02 PACS broker -> interface engine
permit tcp host 192.168.10.40 eq 2575 host 192.168.40.12 established
permit tcp 192.168.40.0/24 host 192.168.10.21 eq 443         ! R-03 EMR web app (user-ID:
    radiologists)
permit tcp host 192.168.10.21 eq 443 192.168.40.0/24 established   ! reply has 443 as SOURCE port
deny   ip  192.168.40.0/24 192.168.10.0/24 log               ! all else radiology -> HIS
deny   ip  192.168.10.0/24 192.168.40.0/24 log               ! all else HIS -> radiology (H-05 sits
    above)
```

Note that the reply entries are written with the ports reversed: a reply from a server listening on 443 arrives with 443 as its *source* port and an ephemeral destination port.

8.5 NGFW inspection policy

8.5.1 Application identification

App-ID is applied to every permit that crosses a zone boundary. Where a rule names an application, traffic on the permitted port that is *not* that application is dropped and logged. Examples:

- DV-03 permits only `A_HL7` on 2575. A device that opens a shell or tunnel on 2575 is blocked even though the port is permitted.
- C-07 permits web browsing but blocks the application categories *remote access* (TeamViewer, AnyDesk), *tunnelling* (SSH over 443, Tor, generic VPN), *peer-to-peer* and *personal cloud storage upload*.
- QUIC (udp/443) is blocked for zones with TLS inspection so that browsers fall back to TCP/443, which can be inspected.

8.5.2 URL filtering

Malware, phishing, C2, newly registered domains, adult, gambling and illegal categories are blocked in every zone. For CLINICAL we also block personal file sharing, make social media read-only and alert

on webmail and uncategorised sites. RESEARCH (through the proxy) gets alerts rather than blocks for file sharing, webmail and uncategorised sites. GUEST and VENDOR-WIFI only get the common blocks, since that is not our data. Health, medicine and government sites are allowed everywhere.

8.5.3 File blocking and anti-malware

CLINICAL and RADIOLOGY cannot download executables (`.exe, .msi, .dll, .scr, .ps1, .hta`) except from IT update URLs. Office files with macros from the internet are blocked, and unknown files are sandboxed before delivery. In RESEARCH we alert on archive uploads over 100 MB and on any file matching the DLP dictionary (patient names, MRN pattern, Aadhaar pattern).

8.5.4 Intrusion prevention profiles

Table 8.3: IPS profile per zone pair

Zone pair	Profile	Focus
Internet → DMZ portal	Strict, block	Web-application attacks: SQLi, XSS, path traversal, known CVEs for the portal stack
CLINICAL → HIS	Strict, block	Exploits against EMR and pharmacy servers; brute force
DEVICES → HIS	Medical, block	HL7 anomalies; scanning from a device; known medical-device CVEs
RADIOLOGY → HIS	Strict, block	SMB, RDP and SQL exploitation attempts
All zones → internet	Default, block	C2 beacons, exploit kits, crypto-mining
GUEST, VENDOR-WIFI	Default, alert	Visibility without impact on visitors

IPS is introduced in alert mode for two weeks per zone pair so that false positives against clinical applications can be tuned before blocking.

8.5.5 TLS inspection policy

Table 8.4: What is and is not decrypted

Traffic	Decrypt?	Reason
CLINICAL → internet (managed PCs)	Yes	Malware and exfiltration visibility; PCs trust the local CA through group policy
RESEARCH via H_ PROXY	Yes	“Inspected egress” is a requirement of the brief
Internet → portal	Yes (inbound)	Portal certificate and key are on the NGFW; enables IPS on requests
Banking, health and government categories	No	Staff privacy; legal risk
Certificate-pinned applications (exemption register)	No	They refuse interception and would break
GUEST and VENDOR-WIFI	No	Devices do not trust our CA; not our data
DEVICES and modalities	No	Cannot install our CA; no change to device configuration
HIS → partner SaaS (H-02)	No	Mutual TLS with partner; inspected by App-ID and destination only

8.5.6 Identity integration

The NGFW learns user-to-IP mappings from domain-controller logons and 802.1X accounting, so rules C-02 to C-06 and R-03 follow the user rather than the PC. A nurse gets the same access at any ward PC, and an unknown user on a clinical address only matches C-01 and C-07.

8.5.7 Research egress through an explicit proxy

Research hosts have no direct internet rule. They go through H_PROXY, an application-layer proxy that decrypts, applies file and DLP checks and logs the full URL with the researcher's name. The extra latency of a proxy is acceptable here because bioinformatics transfers are not time-critical and the data is sensitive.

9 Critique of the Reference Design

Prepared by: Vedhesh Dhinakaran **Scope:** Gaps in the case brief and our corrections

The case brief proposes a sound direction but leaves gaps that a regulator or an attacker would find. We list them in order of severity, with the correction made in this report.

Table 9.1: Gaps in the reference design and our corrections

#	Gap in the brief	Why it matters	Correction in this report
1	The radiology rule permits the *whole* radiology /24 to reach 192.168.10.20 on TCP 1433.	This is the exact path used in incident F2. A newly compromised reading workstation would still reach the EMR database.	No radiology host reaches 1433 (G-03). The legitimate need, results and orders, uses HL7 from the PACS broker only (R-02, H-05).
2	A laptop plugged into a device port (F1) is treated as a firewall problem.	The laptop and the devices share a VLAN; their traffic never reaches the firewall.	802.1X/MAB, quarantine VLAN and port security (Section 5.6).
3	Device peers are protected only by "no peer permits".	Peer traffic is switched; a firewall rule cannot see it.	Private VLAN isolation, with DV-04 for hair-pinned traffic.
4	Device DNS is permitted on UDP only.	DNS falls back to TCP for large and DNSSEC-signed answers; those lookups silently fail.	DV-01 permits TCP 53 as well.
5	Rules are written only for radiology and devices.	Guest, vendor, clinical, research, DMZ and management flows are undefined, so the rule base is not reviewable.	Complete 60-entry rule base (Table 8.2).
6	No management zone, though SSH must be "unreachable from user zones".	Without a defined management network the requirement cannot be expressed as a rule.	Z_MGMT, bastion and G-02.
7	Vendor access "to a maintenance zone" is not designed.	A tunnel with standing access is the old `any any` again.	Ticket-bound, scheduled, recorded access via H_JUMP (VM-01, VM-02).
8	TLS inspection is proposed without exemptions.	Decrypting staff banking and health traffic is a privacy and legal risk; pinned clients break.	Exemption policy (Section 8.5.5).

#	Gap in the brief	Why it matters	Correction in this report
9	"The internet-edge pair is fail-open" is stated for the whole device.	A fully failed-open firewall removes every control, including zone isolation.	Failure mode decided per path; only inspection engines fail open (Table 5.5).

Summary. In our view, gap 1 is the most important finding of this case study. A rule base can look correct line by line while still permitting the attack that caused the redesign. Only by testing the design against the original incidents does the gap become visible, which is why each incident is a test case in Chapter 10 and in the laboratory.

10 Justification and Effectiveness

Prepared by: Vedhesh Dhinakaran **Scope:** Verification matrix, rule-hit review, change control

10.1 Requirement to verification

Every requirement has a design response and a test that proves it. The tests are repeatable, run from a dedicated assessment host in each zone, and are re-run after every change.

Table 10.1: Verification matrix

T	Requirement	Design response	Test and expected result	Rules
1	Stop vendor-to-clinical movement	Default deny; vendor Wi-Fi to internet only	From vendor Wi-Fi: `nmap -sS -Pn -p 1433,2575,3389 192.168.10.20` returns *filtered*	VW-01
2	Close the flat-network hole	Device VLAN reachable only via firewall	From clinical: `nmap -sS -Pn 192.168.30.0/24` returns all *filtered*	C-08, G-03
3	Radiology cannot reach EMR DB (F2)	G-03	From a reading workstation: `nmap -sS -Pn -p 1433 192.168.10.20` is *filtered*; deny log shows G-03	G-03
4	Restrict the device zone	Three named flows	Rule-hit counters show only DV-01..03 and their returns increasing	DV-01..05
5	Device cannot reach internet	DV-05	From device VLAN: `curl -m 5 https://example.com` times out; DV-05 counter increments	DV-05
6	Rogue laptop is quarantined (F1)	802.1X/MAB	Unknown MAC on device port gets a VLAN 999 address or none; SIEM alert raised	access layer
7	Device peer isolation	PVLAN	Pump A cannot ping pump B; ARP for B gets no reply	DV-04
8	See past port numbers	App-ID	SSH tunnelled over 443 from clinical is classified as SSH and blocked	C-07

T	Requirement	Design response	Test and expected result	Rules
9	Detect malicious request on permitted port	IPS on portal	SQLi test string to `/portal/` is blocked; IPS alert logged	D-02
10	Admin path not public	URL path rule	`GET /admin/` from internet returns block page	D-01
11	Management unreachable	G-02	From every user zone: `nmap -p 22,443 192.168.90.0/24` is *filtered*	G-02
12	Guest is internet only	GW-01	From guest: internal ranges *filtered*; `https://example.com` works	GW-01/02
13	Research egress inspected	Proxy only	Direct `curl` without proxy fails; through proxy succeeds and URL is logged with user	RS-02, D-05
14	Keep the campus running	Log-only then enforce; HA	Two weeks log-only with zero clinical tickets; HA failover drops no MLLP session	–
15	Be auditable	Exported policy with per-rule records	Both F2 and F3 reconstructed from logs (Chapter 11, E8)	all
16	No rule drift	Quarterly any-any search	Export contains no permit with source and destination both `any`	all

10.2 Rule-hit counter review

A counter turns "review the rule base" from an opinion into a measurement. A counter that never increments marks a rule that is *dead* (its scope can never match), *obsolete* (the service was retired) or *mis-scoped* (the subnet moved). A counter far above its stated purpose marks a rule doing something nobody intended.

Table 10.2 is a worked example of a monthly review. The figures are illustrative, prepared to show the method; Part IV shows real counters from the laboratory.

Table 10.2: Worked example of a monthly hit-counter review (illustrative figures)

Rule	Last month	This month	Classification	Action
DV-03	4 812 330	4 790 115	Healthy	None; matches device count × message rate
H-02	0	0	Obsolete	Lab partner moved to a new SaaS; update F_ LABPARTNER, then re-check
R-04	0	0	Mis-scoped	PACS archive re-addressed to .13; object H_PACS_ ARCH not updated
VW-02	1 920	1 875	Healthy	None
X-99	12	3 404	Investigate	A new VLAN was added without a zone section; 3 404 sessions hit the final deny
C-06	40	9 750	Over-use	Biomed jump-host sessions far above maintenance tickets; review accounts

10.3 Change control

Every change follows the same path: a ticket with requester, owner, flow, duration and clinical impact; a security review checking that the rule is as narrow as possible and does not shadow or duplicate another; a log-only rehearsal where possible; implementation in an approved window with automatic

rollback unless confirmed within 10 minutes; re-running the relevant tests from Table 10.1; and storing the policy diff, operator and ticket as audit evidence.

10.4 Effectiveness against the original findings

Table 10.3: Original findings and the controls that now stop them

Finding	Layers of control	Proved by
F1 Rogue laptop on device port	802.1X/MAB → quarantine VLAN; PVLAN; DV-01..05; new-MAC alert	T6, T7, lab E3
F2 Radiology to EMR on 1433	Separate zones; G-03; R-02 broker-only HL7; IPS; G-03 alert	T3, lab E2
F3 Vendor Wi-Fi to clinical	`any any` deleted; VW-01..03; vendor access only via ticketed jump host	T1, lab E2

Part IV: Laboratory, Monitoring, Response and Compliance

11 Laboratory Implementation and Results

Prepared by: Vundela Lasya **Scope:** OPNsense lab build, eight experiments, evidence

11.1 Objectives

The laboratory has one purpose: to prove, with evidence we captured ourselves, that the design in Parts II and III stops the three original incidents while keeping required flows working. It also demonstrates the theory in Chapter 2 (stateless versus stateful behaviour, rule shadowing, App-ID and IPS) on real packets.

Note on evidence. Every red box in this chapter marks a screenshot or observation that must be taken from our own lab run. Every "Observed" cell marked *fill in* must be completed with what we actually saw, including any result that differs from the expected one. A difference is a finding to explain, not something to hide.

11.2 Environment

We built the lab on one laptop (16 GB RAM) using VirtualBox 7. The firewall is OPNsense 25.x (2 vCPU, 4 GB RAM) with its bundled Suricata engine running ET Open rules for IPS and the Zenarmor plugin (free edition) for application identification. Each zone has one Alpine Linux 3.20 VM with 512 MB RAM and the tools nmap, tcpdump, tshark, netcat, curl, dig, chrony, dnsmasq and openssh. rsyslog on the host collects a remote copy of the firewall logs.

TEAM TO CAPTURE: Exact OPNsense version (Lobby → Dashboard), VirtualBox version and host specification.

11.3 Topology

The lab keeps five of the ten zones: the three involved in the incidents (HIS, DEVICES, RADIOLOGY), the untrusted vendor/guest Wi-Fi zone, and MGMT. Each zone is a VirtualBox *internal network*, which behaves like an isolated VLAN.

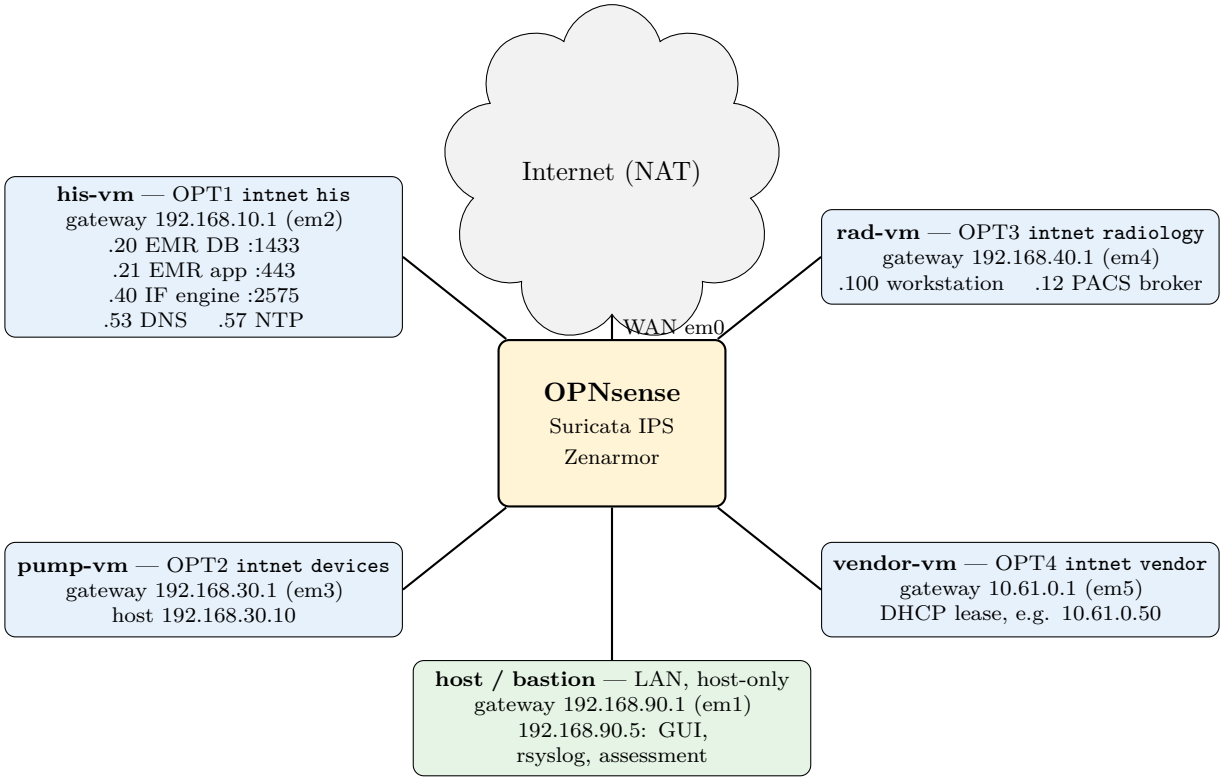


Figure 11.1: Laboratory topology in VirtualBox

Lab limitations. VirtualBox internal networks cannot emulate 802.1X, private VLANs or an NGFW HA pair. Those controls are covered by design and configuration evidence in Part II, not by this lab. One VM per zone stands in for many hosts; IP aliases on `his-vm` stand in for the separate HIS servers.

11.4 Build procedure

1. Firewall VM. Create a FreeBSD 64-bit VM with the OPNsense image. The GUI exposes four adapters, so the rest are added from the command line:

```
VBoxManage modifyvm opnsense --nic1 nat --nic2 hostonly --host-only-adapter2 vboxnet1
VBoxManage modifyvm opnsense --nic3 intnet --intnet3 his --nic4 intnet --intnet4 devices
VBoxManage modifyvm opnsense --nic5 intnet --intnet5 radiology --nic6 intnet --intnet6 vendor
VBoxManage hostonlyif ipconfig vboxnet1 --ip 192.168.90.5 --netmask 255.255.255.0
```

Install from the console, assign `em0` WAN, `em1` LAN and `em2`–`em5` OPT1–OPT4, and set LAN to 192.168.90.1/24.

2. Zones. In the GUI, enable and rename OPT1–OPT4 as HIS (192.168.10.1/24), DEVICES (192.168.30.1/24), RADIOLOGY (192.168.40.1/24) and VENDOR (10.61.0.1/24, DHCP .50–.99). A new OPT interface in OPNsense has no pass rules, so it starts as default-deny, which is what we want.

3. Zone hosts. On `his-vm`, IP aliases stand in for the separate HIS servers and simple listeners stand in for the services:

```
apk add nmap tcpdump tshark netcat-openbsd curl bind-tools chrony dnsmasq openssh python3
for ip in 20 21 40 53 57; do ip addr add 192.168.10.$ip/24 dev eth0; done
ip route add default via 192.168.10.1
nc -lk -s 192.168.10.20 -p 1433 &                    # "EMR database"
nc -lk -s 192.168.10.40 -p 2575 &                    # "HL7 interface engine"
python3 -m http.server 443 --bind 192.168.10.21 &    # EMR app (plain HTTP so IPS can read it)
dnsmasq --listen-address=192.168.10.53 --server=1.1.1.1 --address=/emr.sjv.local/192.168.10.21
echo "allow 192.168.0.0/16" >> /etc/chrony/chrony.conf && rc-service chronyd restart
```

`pump-vm` is 192.168.30.10, `rad-vm` is 192.168.40.100 with alias .12 for the PACS broker, and `vendor-vm` uses DHCP and the firewall as resolver.

4. Aliases and rules. Under *Firewall* → *Aliases* we created H_EMR_DB, H_EMR_APP, H_IFENGINE, H_DNS, H_NTP, H_PACS_BROKER, N_RFC1918 and S_MLLP with the addresses of Table 5.3. OPNsense applies interface rules to traffic *entering* that interface, first match wins. Table 11.1 is the subset of our rule base that applies to the lab zones; every rule logs and carries its rule ID in the description.

Table 11.1: Lab rule set as entered in OPNsense

Interface	Action	Source	Destination	Port	Description
DEVICES	Pass	DEVICES net	H_DNS	53 (TCP/UDP)	DV-01 DNS
DEVICES	Pass	DEVICES net	H_NTP	123 (UDP)	DV-02 NTP
DEVICES	Pass	DEVICES net	H_IFENGINE	S_MLLP	DV-03 HL7 MLLP
DEVICES	Block	DEVICES net	any	any	DV-05 strict egress
RADIOLOGY	Block	RADIOLOGY net	H_EMR_DB	any	G-03 no EMR DB
RADIOLOGY	Pass	H_PACS_ BROKER	H_IFENGINE	S_MLLP	R-02 broker HL7
RADIOLOGY	Pass	RADIOLOGY net	H_EMR_APP	443	R-03 EMR app
RADIOLOGY	Pass	RADIOLOGY net	H_DNS, H_ NTP	53, 123	R-01 core
RADIOLOGY	Block	RADIOLOGY net	any	any	R-06 default deny
VENDOR	Pass	VENDOR net	This Firewall	53	Local resolver
VENDOR	Block	VENDOR net	N_RFC1918	any	VW-01 no internal
VENDOR	Pass	VENDOR net	! N_RFC1918	80, 443	VW-02 internet only
VENDOR	Block	VENDOR net	any	any	VW-03 default deny
HIS	Pass	H_DNS	any	53	H-07 recursion
HIS	Pass	H_NTP	any	123	H-06 upstream time
HIS	Block	HIS net	any	any	H-08 default deny
LAN (MGMT)	Pass	192.168.90.5	any	any	M-01/02 bastion (lab only)

TEAM TO CAPTURE: Screenshot of each interface's rule list (Firewall → Rules) showing order, actions and descriptions.

5. Logging, IPS and App-ID. Remote logging sends `filterlog` and `suricata` to rsyslog on 192.168.90.5 (UDP 514 in the lab; TLS on 6514 in production). For Suricata we disabled hardware CRC, TSO and LRO offloading (needed for inline mode), enabled IPS mode on all four zone interfaces, downloaded the ET Open sets (`web_server`, `scan`, `attack_response`, `malware`) and added a policy that sets them to *Drop*. Zenarmor was installed from *System* → *Firmware* → *Plugins* on RADIOLOGY and VENDOR, blocking the Remote Access and Tunnelling categories and the SSH application.

TEAM TO CAPTURE: Suricata administration page (IPS mode on, interfaces selected) and the Zenarmor application-control policy.

11.5 Experiments

Each experiment gives the purpose, what we run and what we expect. The results go in Table 11.2.

E1: Baseline (the old flat network). We temporarily put *Pass any → any* at the top of RADIOLOGY and VENDOR to mimic the old `any any`, then scan:

```
rad-vm$    nmap -sS -Pn -p 1433,2575,443 192.168.10.20-40
vendor-vm$ nmap -sS -Pn -p 1433,2575,443,22 192.168.10.0/24 192.168.30.0/24
```

We expect 1433 on the EMR database to be *open* from radiology (F2) and the vendor laptop to see HIS and device hosts (F3).

TEAM TO CAPTURE: nmap output from rad-vm and vendor-vm with the allow-all rule in place.

E2: Segmentation enforced. With the allow-all rules removed, we repeat E1 and test the flows that should still work:

```
rad-vm$    nmap -sS -Pn -p 1433 192.168.10.20          # filtered (G-03)
rad-vm$    curl -m 5 http://192.168.10.21:443/          # works (R-03)
rad-vm$    nc -s 192.168.40.12  -zv 192.168.10.40 2575  # works: PACS broker (R-02)
rad-vm$    nc -s 192.168.40.100 -zv 192.168.10.40 2575  # times out: not the broker
vendor-vm$ nmap -sS -Pn -p 1433,2575,3389 192.168.10.20 # filtered (VW-01)
vendor-vm$ curl -m 5 -I https://example.com             # works (VW-02)
```

The Live View (*Firewall → Log Files*) should show blocks labelled `G-03 no EMR DB`.

TEAM TO CAPTURE: nmap and curl outputs, and the Live View filtered on 192.168.40.100 showing the G-03 blocks.

E3: Device zone has three flows and nothing else.

```
pump-vm$ dig @192.168.10.53 emr.sjv.local ; dig +tcp @192.168.10.53 emr.sjv.local   # both answer
pump-vm$ chronyd -Q 'server 192.168.10.57 iburst'                                    # offset shown
pump-vm$ nc -zv 192.168.10.40 2575                                                   # works
pump-vm$ nc -zv -w 3 192.168.10.20 1433 ; curl -m 5 https://example.com              # both fail
pump-vm$ nmap -sn 192.168.40.0/24                                                    # 0 hosts up
opnsense# pfctl -vvsr | grep -A3 "DV-0"                                              # rule counters
```

Only DV-01 to DV-03 should show permitted traffic; DV-05 should count the blocked attempts.

TEAM TO CAPTURE: pump-vm outputs and the `pfctl -vvsr` counters for DV-01 to DV-05.

E4: Stateless versus stateful. This shows the direction and intent failures from Table 2.1 on real packets.

1. Set R-03 to *State type: none*. OPNsense's automatic *pass out* rules keep state and would make the test stateful again, so we also add a floating rule (interface HIS, direction out, quick, pass, RADIOLOGY net → H_EMR_APP:443, state type none). From rad-vm, `curl` to the EMR app should time out, and `tcpdump -ni em2 host 192.168.10.21 and port 443` on the firewall should show the SYN-ACK leaving the server and being dropped by H-08. That is a silent outage caused by a missing reverse rule. If curl still works, the States page will show which automatic rule kept state.
2. Add the reverse rule a stateless design needs (HIS: pass H_EMR_APP port 443 → RADIOLOGY net, state none). curl now works.

3. Abuse it: start `nc -lk -p 8080` on rad-vm and run `nmap -sS -Pn -g 443 -S 192.168.10.21 -e eth0 -p 8080 192.168.40.100` from his-vm. Port 8080 should show *open*, because the "reply" rule lets the server start new connections into radiology.
4. Restore *keep state*, delete the reverse and floating rules, and repeat. curl works, the source-port-443 scan shows *filtered*, and the session appears under *Diagnostics* → *States*.

TEAM TO CAPTURE: tcpdump from step 1, nmap from steps 3 and 4, and the state-table entry for the curl session.

E5: Rule order. On VENDOR we add *Pass VENDOR net* → *any:443* above VW-01 and run `curl -m 5 http://192.168.10.21:443/` from vendor-vm, then move the rule below VW-01 and repeat. In the wrong order the EMR app is reachable and VW-01's counter does not move; in the right order VW-01 blocks it.

TEAM TO CAPTURE: Rule list in both orders, curl results and VW-01 counters.

E6: Attack on a permitted port. R-03 allows radiology to the EMR app on 443. With Suricata off and then on, we send:

```
rad-vm$ curl -m 5 -A "sqlmap/1.8" "http://192.168.10.21:443/portal/?id=1%27%20OR%20%271%27=%271"
rad-vm$ curl -m 5 "http://192.168.10.21:443/portal/?q=1%20UNION%20SELECT%20username,password%20FROM
    %20users"
vendor-vm$ curl -m 5 http://testmynids.org/uid/index.html
```

Without IPS all requests get through, because the firewall sees a valid, permitted session. With IPS on they should be dropped and listed under *Intrusion Detection* → *Alerts*; the last one triggers "GPL ATTACK_RESPONSE id check returned root".

TEAM TO CAPTURE: curl results with IPS off and on, and the Alerts page.

E7: Application identification on 443. We stop the web server on 192.168.10.21:443 and run SSH there instead (`sshd -o ListenAddress=192.168.10.21 -p 443`), then run `ssh -p 443` from rad-vm with Zenarmor off and on. The stateful rule lets SSH through because the port is 443; Zenarmor should classify it as SSH and block it.

TEAM TO CAPTURE: ssh results in both cases and the Zenarmor view naming the application. If the free edition limits this, write down exactly what was available.

E8: Rebuilding an incident from logs. We repeat the F2 and F3 attempts at noted times and pull them from the remote log:

```
grep -E "192\.168\.40\.100|10\.61\.0\.50" /var/log/opnsense.log | grep block | tail -50
```

From this we build a timeline (time, source, destination, port, rule, action) and check it against the times we noted.

TEAM TO CAPTURE: The extracted log lines and the reconstructed timeline.

11.6 Results

Table 11.2: Laboratory results (team to complete the Observed column)

Exp.	Test	Expected	Observed
E1	Radiology → EMR DB 1433, allow-all	open	*fill in*
E1	Vendor → HIS and devices, allow-all	hosts and ports visible	*fill in*
E2	Radiology → EMR DB 1433	filtered; G-03 in log	*fill in*
E2	Radiology → EMR app 443	permitted	*fill in*
E2	Broker / non-broker → 2575	permitted / blocked	*fill in*
E2	Vendor → 1433, 2575, 3389	filtered	*fill in*
E2	Vendor → internet	permitted	*fill in*
E3	Device DNS (UDP and TCP), NTP, MLLP	all succeed	*fill in*
E3	Device → 1433, internet, radiology	all fail	*fill in*
E3	Counters DV-01..05	only DV-01..03 permit hits	*fill in*
E4	Stateless, no reverse rule	silent timeout	*fill in*
E4	Stateless reverse rule abused (`-g 443`)	8080 open	*fill in*
E4	Stateful, same scan	filtered	*fill in*
E5	Broad pass above VW-01	EMR app reachable	*fill in*
E5	Correct order	blocked by VW-01	*fill in*
E6	SQLi on permitted port, IPS off / on	delivered / dropped	*fill in*
E7	SSH on 443, App-ID off / on	permitted / blocked as SSH	*fill in*
E8	Timeline of F2 and F3 from logs	complete	*fill in*

TEAM TO CAPTURE: Export the lab configuration (*System* → *Configuration* → *Backups*) with passwords and keys removed, attach it as a separate file, and paste the output of `pfctl -sr` here as the auditable record of the lab policy.

11.7 Discussion of results

TEAM TO CAPTURE: Two or three paragraphs written after the lab run: which results matched expectations, which did not and why (for example, a Zenarmor free-edition limit or an offloading issue with Suricata), and what that means for the production design.

12 Network Monitoring Requirements and Tools

Prepared by: Vundela Lasya **Scope:** Telemetry, SIEM use cases, monitoring tools

12.1 Requirements

The firewall must produce *evidence*, not just decisions. Table 12.1 lists the telemetry we require, where it comes from, and when it should alert.

Table 12.1: Required telemetry and alert thresholds

Telemetry	Source	Alert condition (initial)	Why
Denied-flow rate by rule	Firewall logs	Rate > 3× 7-day baseline for 10 min	A new source hammering a zone
Any-any detection	Policy export	Any live rule with source and destination `any` other than X-99	Drift back to the old design
Per-rule hit counters	Firewall API	Weekly baseline; zero for 90 days; or > 5× baseline	Dead, obsolete, mis-scoped or over-used rules
Bandwidth and sessions per zone	Flow export	Upload > 2 GB per host per hour from CLINICAL or RESEARCH	Exfiltration; state-table pressure
Concurrent sessions per source	Firewall	> 2 000 sessions from one host	Scanning; DoS; worm
TLS inspection health	NGFW	Decryption failures > 5% of sessions	Clients bypassing inspection or distrusting the CA
Configuration changes	Firewall audit log	Any change without a ticket reference	Unauthorised change
IPS alerts	NGFW	Any critical; any alert from DEVICES	Attacks on permitted ports
New MAC on device port	Switch / NAC	Any	Rogue device (F1)
DNS anomalies	H_DNS	Long or high-entropy names; NXDOMAIN bursts from DEVICES	Tunnelling; DGA malware

12.2 SIEM use cases

Correlation rules are written vendor-neutrally; each maps to a threat in Chapter 3.

Listing 12.1: Example SIEM correlation rules (pseudo-code)

```
UC-01  Multi-zone probing (lateral movement)
  WHEN  fw.action = deny  GROUP BY src_ip  WINDOW 60s
  IF    distinct(dst_zone) >= 3            -> severity HIGH

UC-02  EMR database touched from outside HIS (incident F2)
  WHEN  fw.rule_id = "G-03"                -> severity CRITICAL, page on-call

UC-03  Device zone egress attempt (botnet / phone home)
  WHEN  fw.rule_id = "DV-05" AND dst_zone = internet
  COUNT >= 5 in 10m by src_ip              -> severity HIGH, notify biomed

UC-04  Vendor Wi-Fi reaching for internal ranges (incident F3)
  WHEN  fw.rule_id = "VW-01"  COUNT >= 20 in 5m by src_ip  -> severity MEDIUM
```

```
UC-05  Final deny hit (policy gap)
  WHEN  fw.rule_id = "X-99"                -> ticket to network team

UC-06  Unticketed change
  WHEN  fw.audit.event = config_change AND NOT match(comment, "CHG[0-9]+")
                                           -> severity HIGH
```

12.3 Monitoring tools and techniques

Table 12.2: Tools and how we apply them

Tool	Purpose	Example
SIEM / log analysis	Correlate denies with host events; any-any and deny-rate alerting	UC-01: one host denied in three zones in a minute
tcpdump	Confirm one rule and the direction of a real flow	`tcpdump -ni em3 'net 192.168.30.0/24 and tcp port 2575'`
nmap from each zone	Prove the boundary survived the last change	`nmap -sS -Pn -p 104,2575,1433 192.168.10.20`
tshark	Extract fields an application rule needs	`tshark -r cap.pcap -Y tls.handshake.extensions_server_name -T fields -e tls.handshake.extensions_server_name`
Flow export (IPFIX / NetFlow v9)	Trend zone pairs and applications over time	Session records to SIEM over syslog-TLS
pfctl / firewall API	Rule-hit counters and state table	`pfctl -vvsr`; `pfctl -ss`
Suricata EVE logs	Alert detail, detected application protocol	`jq 'select(.event_type=="alert")' eve.json`

12.4 Safe scanning in a hospital

Scans run from a dedicated assessment host in each zone and only under change control. The DEVICES zone is tested read-only (passive capture and checks against the firewall's own interface), because an active sweep can crash or alarm a patient monitor. Active device testing is done only on spare units in the biomedical workshop.

13 Incident Detection and Response

Prepared by: Vundela Lasya **Scope:** Response lifecycle and playbooks

13.1 Approach

We follow the NIST SP 800-61 lifecycle (preparation, detection and analysis, containment and recovery, post-incident review). In practice every playbook runs the same steps: detect, isolate, verify, preserve, rebuild, close the gap and review. Evidence (session records, flow data, config diffs) is exported *before* any containment rule is added, so it is not overwritten. The three original findings are the test cases for these playbooks.

13.2 Playbooks

Table 13.1: Incident response playbooks

Playbook	Detect	Isolate and verify	Preserve and rebuild	Close the gap
PB-1 Vendor laptop probing internal ranges (F3)	UC-04, UC-01; VW-01 denies	Source deny on IP/MAC; drop the client from the wireless controller; nmap from vendor Wi-Fi shows internal ranges filtered	Firewall, wireless and DHCP records; notify the vendor and ban the device until cleared	Revoke any open VENDOR-MAINT tickets for that vendor
PB-2 Workstation reaching for the EMR DB (F2)	UC-02 (any G-03 hit is critical); IPS alerts	Quarantine the port through NAC; source deny; nmap to 1433 from radiology shows filtered	Disk and memory image; EMR login audit; re-image and rotate credentials	Find and fix the entry point (phishing, USB)
PB-3 Unknown device on a device port (F1)	NAC new-MAC alert; MAB failure; port-security violation	Port is already in VLAN 999 by design; confirm no lease in VLAN 30 and no flows	Switch and NAC logs; CCTV request	Lock or move exposed ports; brief engineers
PB-4 Compromised medical device	UC-03 (DV-05 egress); IPS on DV-03; DNS anomaly	Isolate *only that device*, after clinicians have a replacement at the bedside; never shut the VLAN	Device log buffer (biomed), port capture; vendor re-flash via the vendor access process	Review the device's MDS2 form and tighten its flows
PB-5 Bulk exfiltration over TLS	Upload-volume alert; App-ID shows personal cloud storage; DLP match	Block the destination and the host's internet access, keeping EMR access if clinical work must continue	Decrypted session metadata, proxy and flow logs	Assess whether a personal-data breach occurred and start notification

Shutting down the whole device VLAN is itself a patient-safety incident, which is why PB-4 isolates one device at a time.

13.3 Roles and communication

Table 13.2: Responsibility matrix (R = responsible, A = accountable, C = consulted, I = informed)

Activity	SOC	Network	Biomed	CISO	Clinical lead
Triage alert	R	C	I	I	–
Isolate workstation / port	C	R	–	A	I
Isolate medical device	C	R	R	A	C
Evidence preservation	R	C	C	A	–
Regulatory notification	C	–	–	R/A	I
Lessons learned	R	R	C	A	C

Statutory reporting. Cyber incidents of the types listed in the CERT-In directions of April 2022 are reported to CERT-In within six hours of being noticed. A personal data breach is notified to the Data Protection Board of India and to affected individuals under the Digital Personal Data Protection Act, 2023 and its rules. The CISO owns both notifications.

14 Continuous Monitoring, Risk Management and Compliance

Prepared by: Vundela Lasya **Scope:** Review cadence, TLS governance, compliance mapping

14.1 The rule base as a managed asset

Table 14.1: Continuous monitoring calendar

Cadence	Activity	Owner
Daily	Review critical alerts (UC-02, UC-03); confirm log ingestion from both firewall tiers	SOC
Weekly	Baseline per-rule hit counters; review X-99 hits; check TLS-inspection failure rate	SOC
Monthly	Hit-counter hygiene review (Section 10.2); retire dead rules and expired exceptions; patch firewall signatures	Network + SEC
Quarterly	Search for `any`; written justification for each survivor; re-run the full verification matrix (Table 10.1); review every rule with "Q"	SEC
Half-yearly	Formal rule-base review with business owners (PCI DSS 1.2.7)	CISO
Annually	Segmentation penetration test (PCI DSS 11.4.5); risk register refresh; IR tabletop exercise	CISO
On change	Re-baseline flows after every device refresh, since each replacement changes the flows it needs	Biomed + Network

14.2 TLS inspection governance

- The interception CA's lifecycle (creation, storage, rotation, revocation) is owned by IT security. The private key is non-exportable.
- A client-exception register lists pinned applications and unsupported devices, with an owner and a review date for each entry.
- Inspection failure rate is a monitored control (Table 12.1). A spike means clients are bypassing inspection or no longer trust the certificate.
- Decrypted content is not stored; only metadata and alerts are retained.

14.3 Metrics

We report these to management every month, with the target in brackets: rules without an owner or review date (0), permit rules with `any` source and destination (0), expired exceptions still active (0), changes without a ticket (0), rules with no hits for 90 days (reviewed within 30 days), time to contain a G-03 alert (under 30 minutes), TLS inspection failure rate (under 2%), and verification tests passing after a change (100%).

14.4 Compliance mapping

Regulations prescribe outcomes, not a specific firewall technology. Table 14.2 shows which part of the design provides the evidence for each obligation. HIPAA is a United States law; it is included because the case brief names it and it is a widely used benchmark for hospital security. The Indian obligations apply directly to Sanjivani.

Table 14.2: Compliance mapping

Framework	Requirement	Where this design meets it
HIPAA	§164.308(a)(1)(ii)(A) Risk analysis	Asset register, STRIDE, risk register (Ch. 3, 4)

Framework	Requirement	Where this design meets it
HIPAA	§164.308(a)(1)(ii)(B) Risk management	Residual risk and controls; continuous monitoring calendar
HIPAA	§164.308(a)(1)(ii)(D) Information system activity review	Telemetry and SIEM use cases (Ch. 12)
HIPAA	§164.308(a)(5)(ii)(B) Protection from malicious software	IPS, file blocking, URL filtering
HIPAA	§164.308(a)(6) Security incident procedures	Playbooks PB-1 to PB-5 (Ch. 13)
HIPAA	§164.308(a)(7) Contingency plan	HA pairs, failure modes, off-site backup (M-05, R-04)
HIPAA	§164.312(a)(1) Access control	Zones, default deny, identity-based rules
HIPAA	§164.312(b) Audit controls	Logging of every decision; exported policy diffs
HIPAA	§164.312(c)(1) Integrity	Default deny plus IPS; DAI and DHCP snooping
HIPAA	§164.312(d) Person or entity authentication	802.1X, MFA on bastion and vendor IPsec
HIPAA	§164.312(e)(1) Transmission security	Protocol register: TLS, IPsec, SNMPv3, syslog-TLS
PCI DSS v4.0	1.2.1, 1.2.2 Configuration standards and change control for network security controls	Rule metadata, change control (Ch. 10)
PCI DSS v4.0	1.2.5 All allowed services and ports identified and approved	Protocol register; every rule has a requirement and owner
PCI DSS v4.0	1.2.7 Configurations reviewed at least every six months	Half-yearly review (Table 14.1)
PCI DSS v4.0	1.3.1, 1.3.2 Inbound and outbound traffic to the CDE restricted	C-04 only (billing group to H_ BILLING); H-08
PCI DSS v4.0	1.3.3 Controls between wireless networks and the CDE	GW-01, VW-01; no wireless route to HIS
PCI DSS v4.0	10.2 Audit logs; 10.4.1 daily review	Logging; daily SOC review
PCI DSS v4.0	11.4.5 Segmentation controls tested	Verification matrix; annual segmentation test
PCI DSS v4.0	11.5.1 Intrusion detection / prevention	Suricata/NGFW IPS profiles
DPDP Act 2023	Reasonable security safeguards; breach intimation to the Board and data principals	Whole design; PB-5 notification step
CERT-In 2022	Report incidents within 6 hours; keep ICT logs for 180 days in India; synchronise clocks to NIC/NPL NTP	Ch. 13; SIEM retention 180 days; H-06
IEC 80001-1:2021	Risk management for health IT networks that incorporate medical devices	Device zone design, biomed ownership, PB-4

Framework	Requirement	Where this design meets it
NIST SP 800-41r1	Firewall policy based on default deny; policy management and testing	Rule-base disciplines (Ch. 8)

15 Conclusion

Through this case study we found that the hospital's real problem was not just the type of firewall but where it was placed. A stateless filter protected only the edge of a flat network, and a single forgotten `any any` rule removed even that protection. All three incidents happened on paths the firewall never saw.

Our redesign tackles this at four levels. On **firewall type**, stateful inspection removes the five failures of stateless filtering and the NGFW adds the application, payload and user awareness a hospital needs. On **placement**, ten zones with every inter-zone flow routed through an NGFW pair put the firewall on every path that matters, while access-layer controls handle what no firewall can see. On **policy**, the 60-rule base is default-deny, correctly ordered and fully documented, so every decision traces to a rule, an owner and a log entry. On **testing**, checking the design against the original incidents is how we found that the brief's own radiology rule would still have allowed F2. This matters most in the device zone, where devices that cannot be patched or run security software are protected only by a rule set allowing three named flows and nothing else.

15.1 Limitations and future work

Our zone model still trusts traffic inside a zone. A move towards Zero Trust, with per-session authorisation and micro-segmentation, is the natural next step and is covered in case study CS11. Network detection and response (NDR) on internal switch ports would add visibility inside zones. Our lab also could not emulate 802.1X, private VLANs or HA failover, so testing on physical switches would be a useful follow-up.

References

[1] Department of CSE, *23CSE336 Secure Networks, Case Study CS07: Replacing a Stateless Packet Filter with Segmentation and an NGFW in a Hospital Network*, course material.

[2] K. Scarfone and P. Hoffman, *Guidelines on Firewalls and Firewall Policy*, NIST Special Publication 800-41 Revision 1, 2009.

[3] NIST, *Incident Response Recommendations and Considerations for Cybersecurity Risk Management*, Special Publication 800-61 Revision 3, 2025.

[4] U.S. Department of Health and Human Services, *HIPAA Security Rule*, 45 CFR Part 164, Subpart C.

[5] PCI Security Standards Council, *Payment Card Industry Data Security Standard v4.0.1*, 2024.

[6] Government of India, *The Digital Personal Data Protection Act, 2023* (Act No. 22 of 2023).

[7] CERT-In, *Directions under sub-section (6) of section 70B of the Information Technology Act, 2000*, No. 20(3)/2022-CERT-In, 28 April 2022.

[8] IEC 80001-1:2021, *Application of risk management for IT-networks incorporating medical devices — Part 1: Safety, effectiveness and security in the implementation and use of connected medical devices or connected health software.*

[9] NEMA, *DICOM PS3.15: Security and System Management Profiles* and *PS3.8: Network Communication Support for Message Exchange.*

[10] E. Rescorla, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, 2018.

[11] C. Kaufman et al., *Internet Key Exchange Protocol Version 2 (IKEv2)*, RFC 7296, 2014.

[12] MITRE, *ATT&CK for Enterprise*, `https://attack.mitre.org`.

[13] Deciso B.V., *OPNsense Documentation*, `https://docs.opnsense.org`.

[14] OISF, *Suricata User Guide*, `https://docs.suricata.io`.